

UF5

Aplicación de mecanismos de seguridad activa: redes

Ciberseguridad

ÍNDICE

Introducción.....	04
Objetivos.....	05
Mapa conceptual	06
1. Seguridad de red	07
1.1. Amenazas y ataques en redes.....	07
1.2. Tipos de ataques comunes en redes	08
A. Ataques de interceptación y espionaje	08
B. Ataques de denegación de servicio	09
C. Ataques de ingeniería social	10
D. Malware en redes	11
1.3. Intrusiones externas vs. intrusiones internas	12
A. Seguridad en conexiones a redes no seguras	13
B. Medidas para mitigar intrusiones.....	14
1.4. Seguridad en los accesos de red.....	15
A. Arranque de servicios	15
B. Puertos	16
2. Cortafuegos en equipos y servidores	19
2.1. Funciones principales de un cortafuegos	19
2.2. Tipos de cortafuegos	20
A. Según su tecnología.....	20
B. Según su ubicación	21

2.3. Arquitectura de cortafuegos	23
A. Modelos de arquitectura de firewall	24
B. Instalación de cortafuegos	24
C. Utilización de cortafuegos en un sistema o servidor	26
D. Logs y registros de actividad	32
3. Proxy y seguridad en redes	36
3.1. Conceptos básicos y funcionalidad del proxy	36
3.2. Tipos de proxy	38
3.3. Ejemplos de servidores proxy	39
A. Squid	39
B. CCProxy	39
3.4. Configuración de clientes proxy	40
3.5. Instalación y configuración del proxy Squid	41
Solucionario casos prácticos	47
Enlaces de interés	50
Glosario	51
Bibliografía	54

Introducción

En la era digital, la seguridad de redes se ha convertido en una prioridad crítica para empresas, Gobiernos y usuarios de todo tipo. Cada conexión representa una posible puerta de entrada, y protegerla es tarea de profesionales altamente capacitados. ¿Estás preparado para enfrentarte a amenazas reales?

Entender cómo actúan los ataques —desde el phishing hasta el ransomware, desde el sniffing hasta las inyecciones SQL— te permitirá anticiparte a los riesgos. Debes saber diferenciar entre una intrusión interna y una externa, configurar cortafuegos por estado o por paquetes, y elegir correctamente entre un proxy transparente o uno inverso. Imagina estar a cargo de la protección de una red empresarial y que, de pronto, el tráfico se dispara. Un ataque de denegación de servicios ha comenzado, por lo que debes actuar con rapidez: filtrar IP maliciosas, reforzar reglas en el cortafuegos y analizar logs en busca del origen. Tu formación, tu capacidad para leer registros y tu conocimiento en protocolos como HTTPS o VPN marcarán la diferencia entre el colapso y el control.

Ya seas un administrador de seguridad, que define políticas y gestiona accesos, o un analista, que detecta anomalías en tiempo real, los profesionales como tú sois clave. Un ingeniero de redes implementa zonas desmilitarizadas y segmenta infraestructuras, mientras que, si te encargas de realizar una prueba de penetración, tendrás que simular ataques para fortalecer la seguridad.

Objetivos

X

Conocer los riesgos de conectarse a redes no seguras, mitigarlos y determinar la necesidad de seleccionar los servicios que se arrancarán en un sistema.

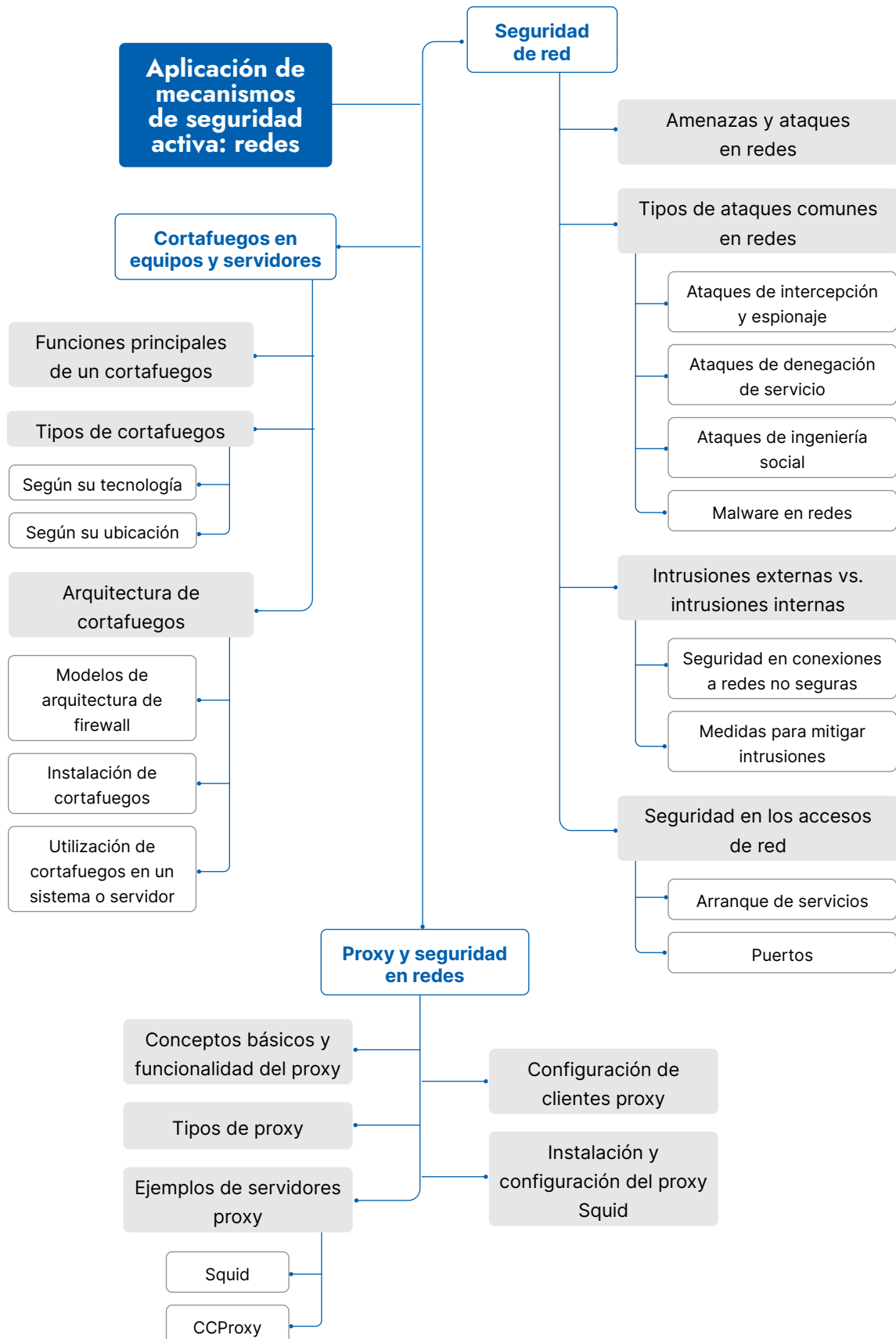
X

Ser capaz de identificar los diferentes tipos de cortafuegos que existen, así como la topología de red a nivel de seguridad, y configurar algunas reglas sencillas de filtrado.

X

Distinguir entre los diferentes tipos de servidores proxy y conocer su funcionamiento y su configuración.

Mapa conceptual



01 Seguridad de red

En la actualidad, la seguridad en redes es un pilar fundamental para garantizar la integridad, la disponibilidad y la confidencialidad de los datos transmitidos a través de infraestructuras empresariales y domésticas. A medida que las amenazas evolucionan, las organizaciones deben implementar **medidas de protección en redes tanto cableadas como inalámbricas**, asegurando que los dispositivos y sistemas conectados operen en un entorno seguro.

1.1. Amenazas y ataques en redes

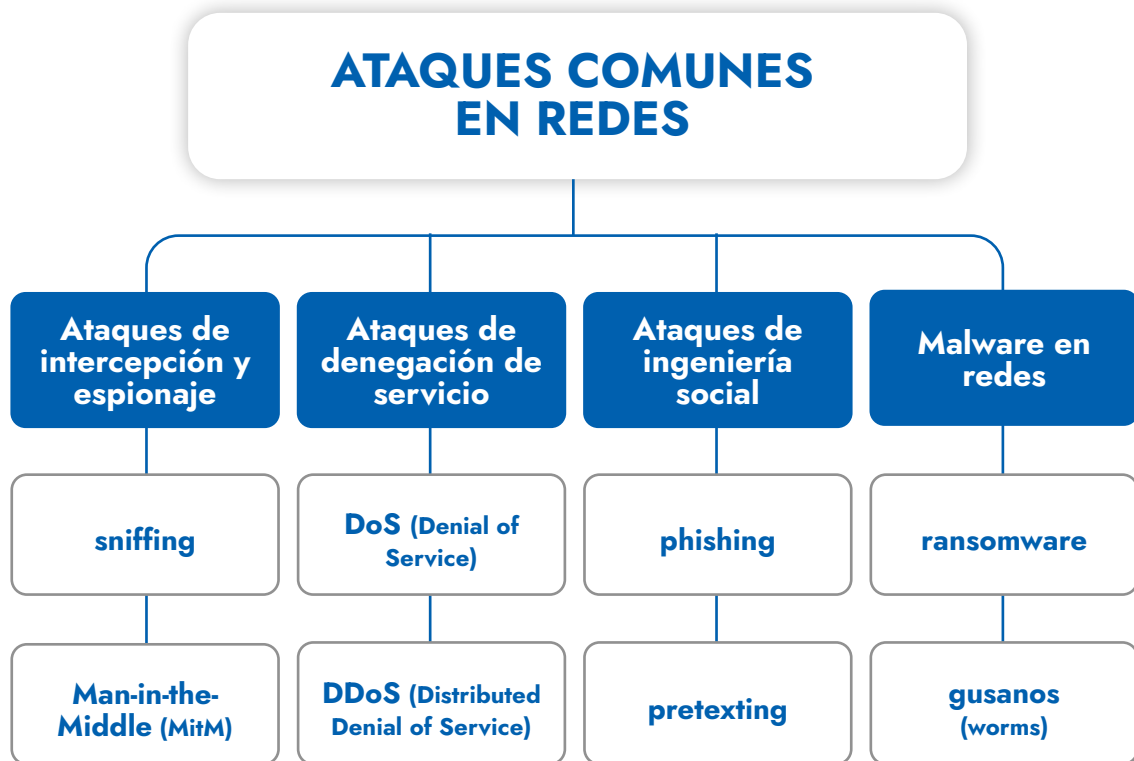
DEFINICIÓN

En el ámbito de la ciberseguridad, las **amenazas en redes** se refieren a cualquier evento o acción que pueda comprometer la confidencialidad, la integridad o la disponibilidad de los datos transmitidos o almacenados en una infraestructura digital. Los atacantes pueden aprovechar vulnerabilidades en los sistemas, en las redes o incluso en el factor humano para llevar a cabo sus acciones maliciosas.

Existen muchos tipos de ataques que pueden afectar a la seguridad de una red, pero, antes de nada, hay que distinguir los ataques activos y los pasivos.

Los **ataques pasivos** no alteran el sistema, sino que su objetivo es obtener información sin ser detectados, por ejemplo, el sniffing (interceptar tráfico de red); por otro lado, los **ataques activos** buscan modificar o afectar de alguna manera el funcionamiento del sistema que se ataca, por ejemplo, los ataques de inyección de SQL, que buscan entrar en una base de datos, los de ransomware, que cifran los datos para pedir un rescate, o los de DoS (denegación de servicio), que tratan de tumbar un servicio para que deje de estar disponible.

1.2. Tipos de ataques comunes en redes



Las redes informáticas están constantemente expuestas a diversas amenazas. Los atacantes utilizan diferentes técnicas para interceptar información, bloquear servicios, engañar a los usuarios o instalar software malicioso en los sistemas. A continuación, se explican los tipos de ataques más comunes en redes, sus características y cómo pueden afectar a los sistemas.

A. Ataques de interceptación y espionaje

Estos ataques tienen como objetivo **interceptar el tráfico de la red** sin que los usuarios lo noten. Aunque los datos no se modifican, el atacante puede capturar información confidencial, como las credenciales de acceso, los datos bancarios o los correos electrónicos, a través de, por ejemplo, el sniffing (escucha de red).

DEFINICIÓN

El **sniffing** es una técnica en la que un atacante captura los paquetes de datos que viajan por la red. El ataque se implementa con herramientas como Wireshark, que permite ver el contenido de los paquetes enviados entre dispositivos, siempre que la información no esté cifrada. El atacante puede obtener información muy delicada, como contraseñas o números de tarjetas de crédito. Para prevenir este espionaje, se pueden usar protocolos cifrados, como HTTPS, o VPN para ocultar el tráfico de red.

Otro de los ataques de este tipo es el **Man-in-the-Middle (MitM)**, por el que el atacante se sitúa entre dos dispositivos que están comunicándose, sin que ninguno de los dos se dé cuenta, y puede interceptar y modificar los mensajes enviados entre ellos. Es muy habitual que estos ataques se den en redes wifi, engañando al usuario para que se conecte a una red falsa y, a partir de ahí, haciendo pasar todo el tráfico por el atacante. De nuevo, este espionaje se puede evitar con el uso de protocolos cifrados, además de evitando conectarse sin protección a redes wifi abiertas.

EJEMPLO

Un ciberdelincuente crea una **red wifi falsa** en una cafetería con un nombre similar al de la red legítima. Cuando los clientes se conectan, el atacante puede interceptar toda la información que envían, incluyendo sus credenciales bancarias o sus contraseñas.

B. Ataques de denegación de servicio

DEFINICIÓN

Los **ataques de denegación de servicio** buscan colapsar un sistema o servidor enviando una gran cantidad de tráfico hasta que el sistema deja de responder. Por un lado, tenemos el ataque **DoS (Denial of Service)** en el que un solo equipo envía miles de solicitudes a un servidor con la intención de saturarlo; como el servidor recibe tantísimas solicitudes, no puede responder a las solicitudes de verdad y deja de dar servicio. Es como si muchas personas llamaran a un número de teléfono al mismo tiempo, haciendo que nadie pueda comunicarse.

EJEMPLO

Por otro lado, tenemos el ataque **DDoS (Distributed Denial of Service)**, que es una versión más grave del DoS, ya que el ataque proviene de múltiples dispositivos infectados en todo el mundo (botnets). Aquí los atacantes toman el control de miles de computadoras y las usan para atacar un servidor de forma simultánea. En este caso es muy difícil eliminar el tráfico malicioso porque proviene de muchos lugares diferentes, por lo que, para prevenir este tipo de ataques, habría que usar firewalls avanzados y sistemas de detección de intrusos.

En 2016, el servicio de Internet en Estados Unidos y Europa fue afectado por un **ataque DDoS** contra Dyn, una empresa de DNS. Los atacantes utilizaron una botnet formada por millones de dispositivos IoT infectados, como cámaras de seguridad y routers, para lanzar el ataque.

C. Ataques de ingeniería social

DEFINICIÓN

A diferencia de los ataques anteriores, que dependen de la tecnología, la **ingeniería social** se basa en engañar a las personas para que entreguen información confidencial o realicen acciones que beneficien al atacante.

Por ejemplo, en el **phishing** (suplantación de identidad) los atacantes envían correos electrónicos o mensajes falsos haciéndose pasar por una entidad confiable (bancos, empresas, servicios de correo) y, mediante estos correos, intentan que el usuario haga clic en un enlace falso para robar sus credenciales. En esos mensajes falsos se pueden incluir archivos adjuntos con malware para infectar el equipo de la víctima, por lo que para prevenirlos hay que evitar hacer clic en los enlaces sospechosos. Los usuarios deben tener una buena formación en los riesgos que existen y puede ser útil la verificación en dos pasos para autenticarse (2FA).

EJEMPLO

Un usuario recibe un **correo supuestamente de su banco** informándole de una «actividad sospechosa» y pidiéndole hacer clic en un enlace para «verificar su cuenta». Si lo hace, será llevado a una página falsa donde los atacantes robarán sus credenciales.

EJEMPLO

Otro ataque propio de la ingeniería social es el **pretexting**, en el que el atacante inventa una historia falsa para obtener información confidencial. Puede usar cualquier medio de comunicación, ya sea por teléfono, correo electrónico o incluso en persona. Para evitarlo se debe verificar siempre la identidad de quien solicita la información.

Un atacante llama al servicio de atención al cliente de una empresa y finge ser un alto ejecutivo que ha olvidado su contraseña. Con técnicas de **manipulación**, logra que le restablezcan el acceso sin pasar por la autenticación normal.

D. Malware en redes

El malware es un software malicioso que puede infectar equipos y propagarse a través de la red. Existen distintos tipos, pero los más comunes en redes son el ransomware y los gusanos (worms).



WEB

Página para la lucha contra el ransomware: <https://www.nomoreransom.org/>.



¿SABÍAS QUE...?

Microsoft Defender for Endpoint es una solución avanzada de seguridad que utiliza inteligencia artificial y análisis de comportamiento para detectar actividades sospechosas asociadas con el ransomware antes de que cause daños.

Sus características clave son:

- » Detección en tiempo real: monitorea cambios anómalos en archivos y procesos.
- » Protección basada en comportamiento: bloquea intentos de cifrado no autorizados.
- » Aislamiento automático de dispositivos infectados: evita la propagación del ataque dentro de la red.
- » Análisis de amenazas con inteligencia artificial: detecta patrones de ataque basados en casos anteriores.



Worms (gusanos informáticos): a diferencia de los virus, los gusanos no necesitan la interacción del usuario para propagarse, es decir, se replican automáticamente por la red sin que nadie los ejecute, pudiendo infectar múltiples dispositivos en poco tiempo. Para detenerlos hay que usar firewalls y mantener todos los sistemas bien actualizados, porque aprovechan las vulnerabilidades de los sistemas.



Phishing: técnica utilizada para engañar a los usuarios mediante correos electrónicos o mensajes falsos que parecen legítimos. Su objetivo es obtener credenciales o información sensible.



Man-in-the-Middle (MitM): un atacante intercepta la comunicación entre dos partes sin que estas lo sepan. Puede modificar o espiar la información transmitida.



Ransomware: este tipo de malware cifra los archivos del usuario y exige un pago (rescate) para desbloquearlos. Se suele propagar a través de phishing y puede afectar a redes enteras paralizando empresas y servicios críticos. La mejor defensa para este ataque es realizar copias de seguridad y no pagar el rescate.



Inyección SQL: un atacante introduce código malicioso en una consulta SQL para manipular bases de datos y obtener acceso a información sensible.



Denegación de servicio distribuida (DDoS): consiste en saturar un servidor o servicio con un gran volumen de tráfico, dejándolo inaccesible para los usuarios legítimos.



Sniffing: técnica usada para capturar paquetes de datos en una red y obtener información sensible, como credenciales de acceso.



Cross-Site Scripting (XSS): Un atacante inyecta scripts maliciosos en páginas web para ejecutarlos en el navegador de los usuarios y robar información o manipular sesiones.



WEB

Cómo prevenir ataques DoS y DDoS:

<https://www.cloudflare.com/es-es/learning/ddos/what-is-a-ddos-attack/>

1.3. Intrusiones externas vs. intrusiones internas

En un entorno de red, los ataques pueden provenir **tanto del exterior como del interior** de la organización. La diferencia entre las intrusiones externas y las internas radica en la procedencia del ataque y el nivel de acceso que tiene el atacante.

Por un lado, las **intrusiones externas** son realizadas por atacantes ajenos a la organización, que buscan explotar vulnerabilidades en la red para conseguir un acceso no autorizado. Algunas técnicas incluyen el escaneo de puertos (identificación de servicios abiertos

en un servidor para explotarlos), los ataques de fuerza bruta (intentos repetitivos para descifrar contraseñas) y la explotación de vulnerabilidades (uso de exploits en software desactualizado).

Un atacante realiza un **escaneo de red en busca de puertos abiertos** y encuentra un servidor expuesto con un sistema obsoleto. Luego, usa un exploit conocido para obtener acceso remoto y robar información.

Las **intrusiones internas** ocurren cuando un empleado o usuario autorizado abusa de sus privilegios o cuando un atacante obtiene acceso desde dentro de la organización. Puede tratarse de una intrusión intencionada, cuando un empleado roba información o instala malware en la red sabiendo lo que hace, o, por el contrario, puede consistir en una intrusión involuntaria en la que un usuario cae en un ataque de phishing o usa passwords muy sencillos y otros se aprovechan de estas vulnerabilidades.

Un empleado descontento copia **archivos confidenciales** y los filtra a la competencia. Otro caso común es un usuario que, por descuido, **deja abierta una sesión** administrativa en un equipo accesible por terceros.

A. Seguridad en conexiones a redes no seguras

Como veremos al abordar los firewalls, **hay entornos que son potencialmente más inseguros que otros**, de ahí que el firewall de Windows distinga tres diferentes perfiles de trabajo.

A la hora de configurar la seguridad de una red, es esencial **identificar las vulnerabilidades inherentes a la conexión** en entornos como Internet, donde la ausencia de medidas de protección puede exponer la información a interceptaciones y ataques. Además, se debe comprender la función y los beneficios de utilizar protocolos seguros (como HTTPS, SSH y VPN, entre otros) que garantizan la confidencialidad, la integridad y la autenticación en la transmisión de datos. Por ejemplo, HTTPS añade la seguridad de un certificado y una clave de encriptación a la transferencia de tráfico web. El protocolo propio de la web HTTP envía la información sin encriptar, de manera que esta es susceptible de ser leída por quien no tiene permiso para ello. Añadir la capa de seguridad que diferencia HTTPS de HTTP impide ese riesgo.

SSH es un protocolo que permite el acceso remoto a servidores, tal como lo haría el protocolo TELNET, pero añadiendo la encriptación de la comunicación. Usar estos protocolos en redes no seguras garantiza que la información no va a ser interceptada por quien no debe y que va a mantener su integridad (no se va a modificar en la transmisión).

Para asegurar la comunicación en entornos no seguros deberían implementarse **túneles cifrados** como VPN, que permiten establecer conexiones seguras incluso cuando se opera en entornos de red no confiables. Hablando de entornos inseguros, las conexiones inalámbricas, por su naturaleza, pueden ser más susceptibles de sufrir ataques, ya que todos los usuarios comparten el canal de comunicaciones, pues todos usan el espectro electromagnético, como si estuvieran todos conectados al mismo cable, y, por lo tanto, los paquetes de comunicación llegan a todos los equipos conectados a la wifi. Por eso es muy importante aplicar mecanismos de seguridad tales como algoritmos de encriptación robusta como WPA3, o protocolos que impliquen la autenticación del usuario, como 802.1x con servidores de credenciales como RADIUS.

B. Medidas para mitigar intrusiones

Tanto las intrusiones externas como las internas pueden minimizarse mediante estrategias de seguridad como las siguientes:

Autenticación multifactor (MFA)	Reduce el riesgo de accesos no autorizados.
Segmentación de red y VLAN	Limita el movimiento lateral de atacantes dentro de la red, es decir, dificulta que un atacante se mueva entre los diferentes segmentos de la red.
Firewalls y listas de control de acceso (ACL)	Restringen conexiones no autorizadas.
Monitoreo con IDS/IPS	Detecta actividades sospechosas dentro y fuera de la red.
Concienciación y formación	Formar a los empleados en buenas prácticas de seguridad.

1.4. Seguridad en los accesos de red

La seguridad en los accesos de red es un aspecto fundamental en la protección de sistemas y redes contra accesos no autorizados y posibles vulnerabilidades. Uno de los puntos clave en este contexto es la **gestión del arranque de servicios y la administración de puertos**, ya que muchos ataques se basan en explotar servicios mal configurados o expuestos innecesariamente en la red.

A. Arranque de servicios

DEFINICIÓN

El **arranque de servicios** en un sistema operativo se refiere a los procesos que se inician automáticamente cuando el sistema se enciende. En entornos de red, estos servicios pueden incluir servidores web, bases de datos, servicios de autenticación y otros, que pueden ser el objetivo de un ataque si no están bien protegidos.

Para minimizar riesgos, es importante adoptar estrategias de seguridad en la gestión de servicios:

Deshabilitar servicios innecesarios

Un sistema con demasiados servicios activos aumenta la superficie de ataque, es decir, puede ser atacado por más sitios. Por lo tanto, si un servicio no es requerido, debe ser desactivado o eliminado. Por ejemplo: en un servidor que solo aloja una base de datos, no tiene sentido tener activo un servidor web si no se usa.

Aplicar principios de mínimo privilegio

Es decir, que los servicios deben ejecutarse con permisos mínimos para reducir el impacto en caso de una intrusión. Por ejemplo, un servidor web Apache no debe ejecutarse con privilegios de root/administrador, sino con un usuario restringido (www-data en Linux).

Uso de listas de control de acceso (ACL) y firewalls

El objetivo es que los servicios críticos solo estén accesibles desde redes autorizadas. Por ejemplo, una base de datos debe ser accesible solo para servidores internos, no directamente desde Internet.

Monitoreo de servicios

Para detectar cualquier servicio que se inicie de manera inesperada, lo que podría indicar un malware o una configuración errónea.

Cada servicio en un sistema escucha en un **puerto específico**. Un puerto abierto sin control adecuado puede convertirse en una vulnerabilidad. Los atacantes suelen escanear las redes en busca de puertos expuestos para encontrar servicios vulnerables.

B. Puertos

Los puertos están organizados según su número y su función:

- » **Puertos bien conocidos (0-1023):** reservados para protocolos estándar como HTTP (80), HTTPS (443), SSH (22), FTP (21), etc.
- » **Puertos registrados (1024-49151):** asignados a aplicaciones específicas como bases de datos y software propietario.
- » **Puertos dinámicos o privados (49152-65535):** utilizados temporalmente por aplicaciones para la comunicación.

Los puertos abiertos pueden ser **explotados** si no están bien configurados con escaneo de puertos, usando herramientas como Nmap para detectar qué servicios están activos en un sistema:

```
nmap -sS -p 1-65535 <IP>
```

Con ataques de **fuerza bruta** contra servicios como SSH (puerto 22) o RDP (puerto 3389) y explotando vulnerabilidades, de modo que un puerto con un servicio desactualizado puede ser objetivo de exploits.

Existen algunas **estrategias** para la protección de puertos:

- » **Cerrar puertos innecesarios:** se pueden listar los puertos abiertos en Linux con:

```
netstat -tulnp
```


O en Windows con:

```
netstat -ano
```


Si un puerto no es necesario, debe cerrarse con reglas de firewall.
- » **Implementar firewalls y reglas de filtrado:** utilizar herramientas como iptables, UFW (Linux) o Windows Firewall para limitar accesos. Por ejemplo, se puede bloquear el acceso SSH desde direcciones IP no autorizadas con:

```
sudo ufw allow from 192.168.1.100 to any port 22
```
- » **Utilizar VPN para restringir el acceso a servicios críticos:** en lugar de exponer RDP o SSH directamente, es mejor que los administradores accedan a la red interna mediante una VPN.
- » **Monitoreo continuo y detección de actividad sospechosa:** herramientas como Snort o Suricata pueden detectar intentos de escaneo de puertos y generar alertas.

1 CASO PRÁCTICO



ANOMALÍAS EN RED Y POSIBLES ATAQUES

La empresa TechSolutions, S. A., ha detectado varias anomalías en su red y sospecha que está siendo víctima de distintos tipos de ataques informáticos. El equipo de seguridad ha identificado los siguientes incidentes:

- » Un usuario reporta que, al ingresar a la página web de la empresa, su navegador ejecuta automáticamente un código malicioso que lo redirige a otro sitio web sospechoso.
- » Varios empleados recibieron un correo electrónico que parecía provenir del Departamento de Recursos Humanos, solicitándoles que actualizaran sus credenciales en un enlace externo. Posteriormente, se detectaron accesos no autorizados a sus cuentas.
- » El servidor de la empresa ha recibido una gran cantidad de tráfico desde múltiples direcciones IP, lo que ha provocado la caída del sitio web.
- » Un administrador de bases de datos observa que un atacante ha logrado ejecutar comandos en la base de datos introduciendo código malicioso en un formulario de inicio de sesión.
- » Se ha descubierto que un intruso ha estado interceptando las comunicaciones internas entre empleados y modificando mensajes antes de que lleguen a su destinatario original.
- » En la red de la empresa, se han encontrado dispositivos sospechosos que están capturando paquetes para obtener información confidencial.
- » Un usuario informa de que sus archivos han sido cifrados y en su pantalla aparece un mensaje exigiendo un pago en criptomonedas para recuperarlos.

Estos son los posibles ataques:

- » Phishing.
- » Man-in-the-Middle (MitM).
- » Ransomware.
- » Inyección SQL.
- » Denegación de servicio distribuida (DDoS).
- » Sniffing.
- » Cross-Site Scripting (XSS).

Relaciona cada situación con el tipo de ataque correspondiente de la lista.

02 Cortafuegos en equipos y servidores

DEFINICIÓN

Los **cortafuegos (firewalls)** son una de las principales herramientas de seguridad en redes, ya que permiten controlar el tráfico que entra y sale de un sistema o red. Su función es permitir, denegar o redirigir paquetes de datos según unas reglas predefinidas, protegiendo los dispositivos y servidores frente a accesos no autorizados o ataques.

2.1. Funciones principales de un cortafuegos

Un cortafuegos bien configurado puede prevenir intrusiones externas, bloquear malware y restringir conexiones peligrosas, garantizando la seguridad de los sistemas conectados a la red.

Los cortafuegos (firewalls) tienen las siguientes funciones principales:

- » **Filtrado de tráfico:** decide qué conexiones están permitidas y cuáles deben bloquearse, usando ACL (listas de control de acceso que indican qué tráfico está permitido; se puede controlar el origen del tráfico, su destino y el puerto al que va dirigido).
- » **Prevención de ataques:** bloquea intentos de intrusión, como escaneos de puertos y ataques DDoS.
- » **Segmentación de red:** permite dividir la red en zonas seguras, como zonas desmilitarizadas (DMZ).
- » **Registro de actividad:** guarda logs de conexiones y eventos de seguridad para auditorías.

DEFINICIÓN

Una **zona desmilitarizada (DMZ)** es un área segura que se usa para proteger los servidores expuestos a Internet sin comprometer la red interna. Si un atacante compromete un servidor en la DMZ, no podrá acceder directamente a la red interna, porque hay un cortafuegos que los separa. Así, la empresa protege sus datos sensibles y sus dispositivos internos.

2.2. Tipos de cortafuegos

Los cortafuegos pueden clasificarse desde distintas perspectivas, como según su tecnología y según su ubicación dentro de la red.

A. Según su tecnología

- » **Filtrado de paquetes:** es una de las funciones esenciales de un cortafuegos. Se basa en analizar los paquetes de datos que intentan atravesar la red y aplicar reglas para permitir o bloquear su paso, según su IP y su puerto (normalmente, podemos filtrar por IP de origen, IP de destino y puertos de destino).

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	0/0 B	*	*	*	LAN Address	443 80 22	*	*	Anti-Lockout Rule	
☐	✓	0/0 B	IPv4 *	LAN net	*	*	*	*	none	Default allow LAN to any rule	
☐	✓	0/0 B	IPv6 *	LAN net	*	*	*	*	none	Default allow LAN IPv6 to any rule	

Fig. 1. Ejemplo de filtrado de paquetes.



WEB

Documentación oficial de pfSense:

<https://docs.netgate.com/pfsense/en/latest/firewall/index.html>

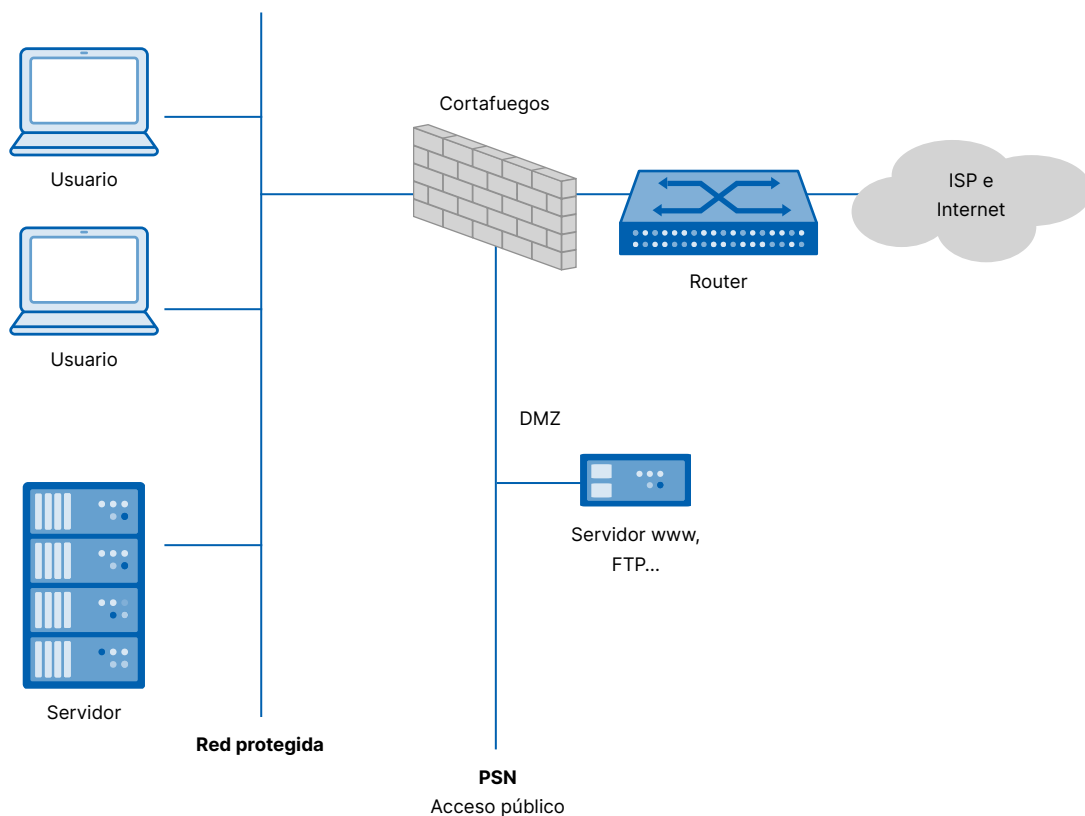
- » **Cortafuegos de estado:** firewall que monitoriza el estado de las conexiones y permite solo tráfico legítimo. Un cortafuegos de estado es un tipo de firewall que no solo revisa cada paquete de datos que entra o sale de la red, sino que también recuerda y analiza las conexiones activas. Imagina que un firewall normal es como un guardia que revisa a cada persona que entra a un edificio sin importar si ya ha estado adentro antes. En cambio, un cortafuegos de estado actúa como un guardia más inteligente que lleva una lista de quién ya entró y salió, permitiendo el paso solo a quienes tienen permiso y están en una conexión legítima.
- » **Firewall de aplicación web (WAF):** es un tipo de cortafuegos que protege páginas web y aplicaciones en línea contra ataques maliciosos. A diferencia de un firewall normal, que solo filtra el tráfico según direcciones IP y puertos, un WAF analiza las peticiones web que llegan a un servidor para detectar y bloquear ataques

específicos. Por ejemplo, el WAF detecta cadenas sospechosas como `OR 1=1` o `DROP TABLE`, que son típicas de los ataques SQL, o puede bloquear caracteres especiales (`'`, `--`, `;`) en campos en los que no deberían usarse, e incluso examina solicitudes POST y GET para detectar intentos de inyección SQL encubiertos.

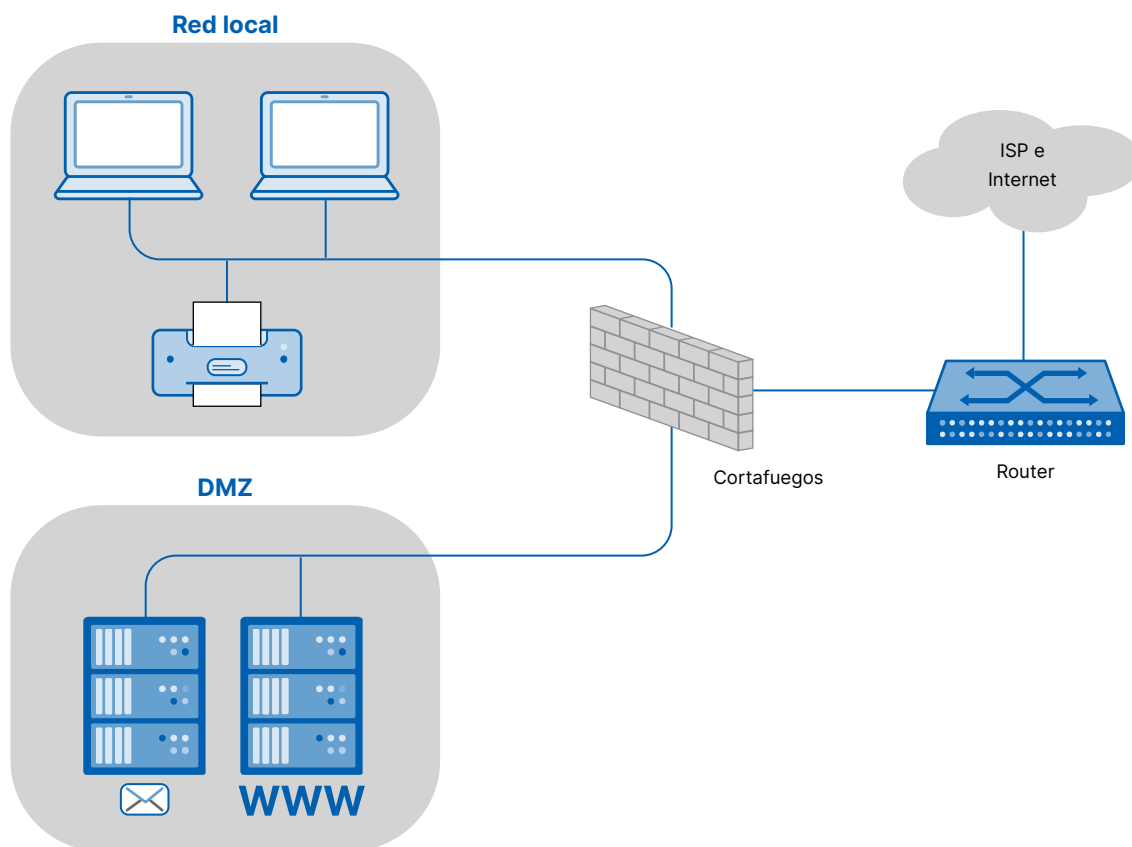
- » **Un firewall basado en proxy:** es un tipo de cortafuegos que actúa como intermediario entre los usuarios de una red e Internet. En lugar de que los dispositivos internos se conecten directamente a los servidores externos, el firewall proxy recibe las solicitudes, las analiza y luego las reenvía al destino, proporcionando una capa adicional de seguridad.

B. Según su ubicación

- » **Cortafuegos perimetrales:** se sitúan en la frontera de la red, protegiendo el tráfico entrante y saliente.
- » **Cortafuegos internos:** se usan dentro de la red para segmentar departamentos o zonas sensibles.
- » **Cortafuegos de host:** instalados en equipos individuales para protegerlos contra amenazas locales.



Esquema 1. Cortafuego perimetral.



Esquema 2. Cortafuego interno.



WEB

¿Qué es una DMZ?

<https://www.incibe.es/empresas/blog/dmz-y-te-puede-ayudar-proteger-tu-empresa>

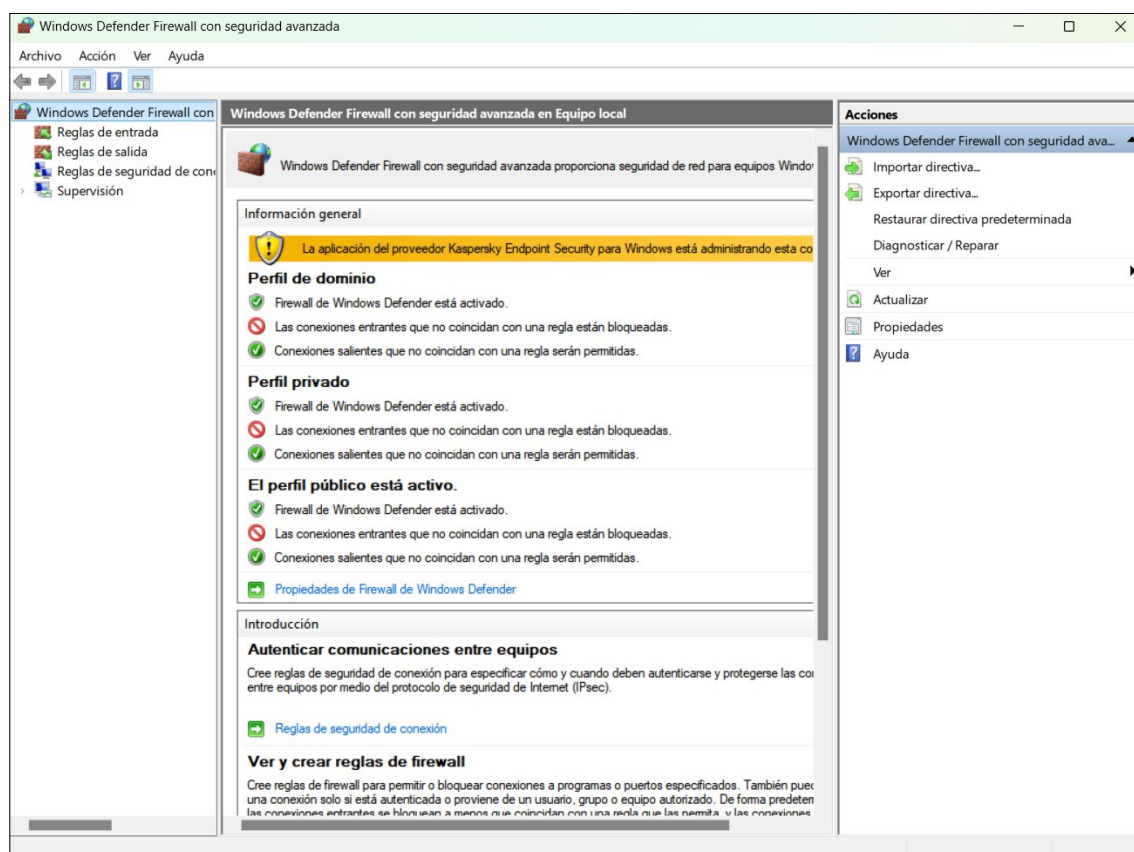


Fig. 2. Firewall de Windows.

2.3. Arquitectura de cortafuegos

DEFINICIÓN

La **arquitectura de un firewall** define cómo se implementan las barreras de seguridad en una red para proteger los sistemas y datos frente a ataques. Existen varias formas de estructurar un firewall, dependiendo de la complejidad de la red y el nivel de seguridad necesario. A continuación, se describen los tres modelos principales de arquitectura de firewall.

A. Modelos de arquitectura de firewall

- » **Arquitectura de una sola capa:** este modelo utiliza un solo firewall para proteger toda la red de amenazas externas. Todas las conexiones entrantes y salientes pasan a través de este firewall, que decide si permite o bloquea el tráfico según sus reglas de seguridad. Este modelo es más fácil de configurar y administrar, menos costoso que otros modelos y suficiente para pequeñas empresas; por otro lado, si se ataca el firewall y se vulnera, toda la red quedará expuesta, por lo que no proporciona segmentación en la red ni es adecuado para redes con muchos servicios expuestos a Internet.
- » **Arquitectura de doble capa:** este modelo usa dos firewalls para proporcionar una protección más avanzada; por un lado, el firewall perimetral, que se ubica en el borde de la red, filtrando el tráfico externo, y, por otro, el firewall interno, que se sitúa entre la red interna y la zona más crítica, proporcionando una segunda barrera de seguridad. Este modelo da mayor seguridad, ya que un solo fallo no compromete toda la red, puesto que se produce una segmentación clara entre la red interna y la externa.
- » **DMZ (zona desmilitarizada):** en este modelo, se crea una zona intermedia entre Internet y la red interna, llamada DMZ (zona desmilitarizada). Se coloca un firewall en cada extremo, un firewall perimetral que protege los servidores expuestos a Internet y otro firewall interno que protege la red interna de posibles ataques desde la DMZ. Dentro de la DMZ se ubican servidores públicos, como páginas web, servidores de correo o bases de datos accesibles desde Internet.

B. Instalación de cortafuegos

Si nos planteamos instalar un cortafuegos, primero hemos de **decidir en qué contexto** vamos a implementarlo, es decir, ¿vamos a instalar un firewall perimetral o un firewall interno entre redes, o tal vez un firewall en el propio servidor? Si el firewall va a ser de host, ¿qué sistema operativo tendrá el servidor al que le instalaremos el firewall? En el caso de instalar un firewall perimetral, podríamos optar por usar una máquina dedicada con un sistema operativo especializado como pfSense, por ejemplo.



WEB

Información sobre instalación de pfSense:

<https://docs.netgate.com/pfsense/en/latest/firewall/index.html>

Por otro lado, si queremos usar un sistema operativo como Linux podemos instalar un firewall para bloquear el tráfico no autorizado con los siguientes comandos:

```
stucom@stucom:~$ sudo apt-get install ufw
[sudo] password for stucom:
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
ufw ya está en su versión más reciente (0.36.1-4ubuntu0.1).
```

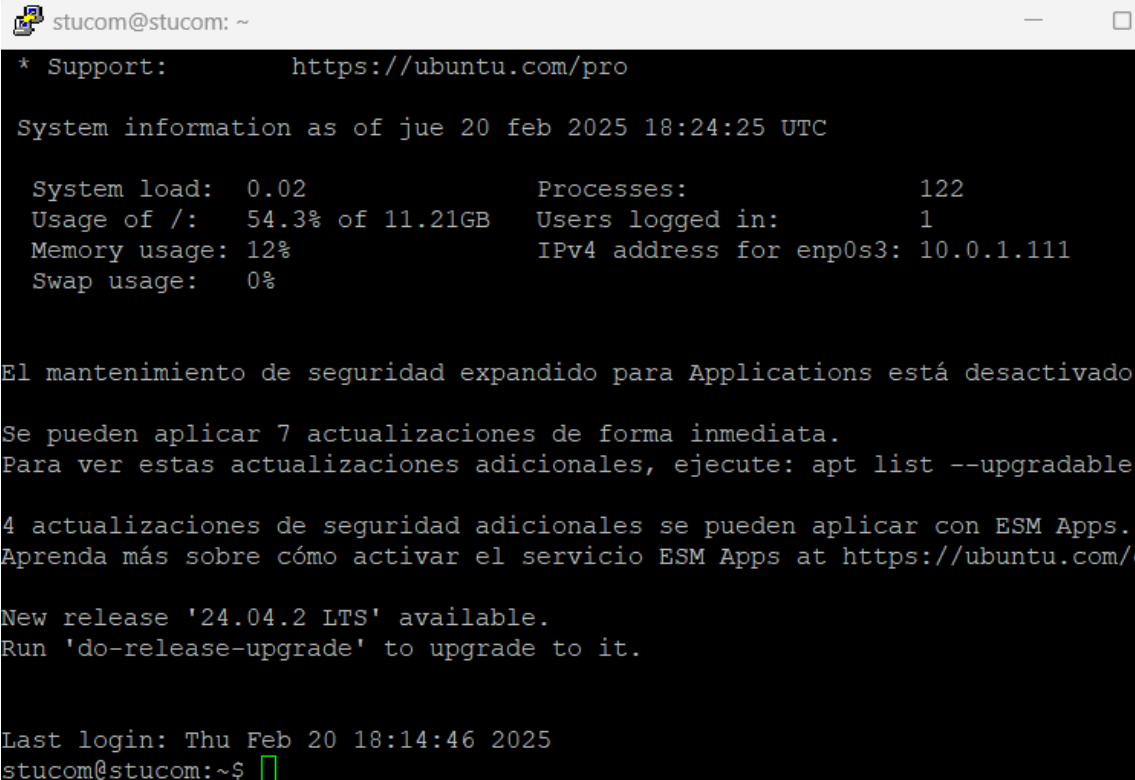
Instalamos el paquete de firewall para Ubuntu ufw (Uncomplicated Firewall):

```
root@stucom:/home/stucom# ufw allow 22/tcp
Rules updated
Rules updated (v6)
root@stucom:/home/stucom# ufw enable
Firewall is active and enabled on system startup
root@stucom:/home/stucom# _
```

Añadimos una regla de ejemplo, como permitir el tráfico al puerto 22, y activamos el firewall con esta regla:

```
root@stucom:/home/stucom# ufw allow 22/tcp
Rule updated
Rule updated (v6)
root@stucom:/home/stucom# ufw enable
Firewall is active and enabled on system startup
root@stucom:/home/stucom# _
```

Al habilitar el tráfico SSH por el puerto 22, podemos conectarnos en remoto a este servidor porque se permite este tráfico:



```
stucom@stucom: ~
* Support:      https://ubuntu.com/pro

System information as of jue 20 feb 2025 18:24:25 UTC

System load:  0.02          Processes:      122
Usage of /:   54.3% of 11.21GB Users logged in: 1
Memory usage: 12%          IPv4 address for enp0s3: 10.0.1.111
Swap usage:   0%

El mantenimiento de seguridad expandido para Applications está desactivado

Se pueden aplicar 7 actualizaciones de forma inmediata.
Para ver estas actualizaciones adicionales, ejecute: apt list --upgradable

4 actualizaciones de seguridad adicionales se pueden aplicar con ESM Apps.
Aprenda más sobre cómo activar el servicio ESM Apps at https://ubuntu.com/

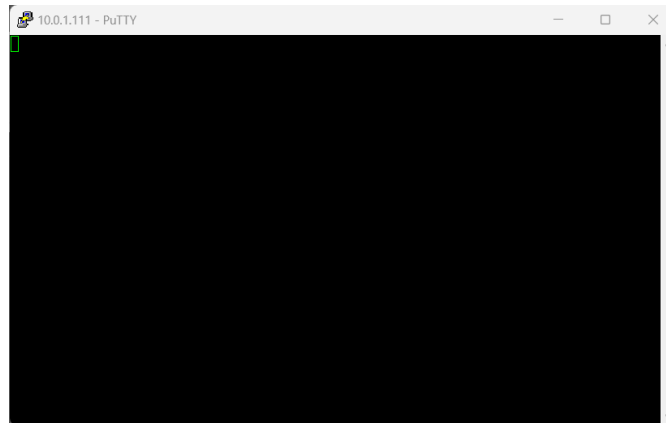
New release '24.04.2 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Thu Feb 20 18:14:46 2025
stucom@stucom:~$
```

Si cerramos ese puerto así:

```
root@stucom:/home/stucom# ufw deny 22/tcp
Rule updated
Rule updated (v6)
root@stucom:/home/stucom# ufw enable
Firewall is active and enabled on system startup
root@stucom:/home/stucom#
```

El resultado es:



No es posible la conexión.

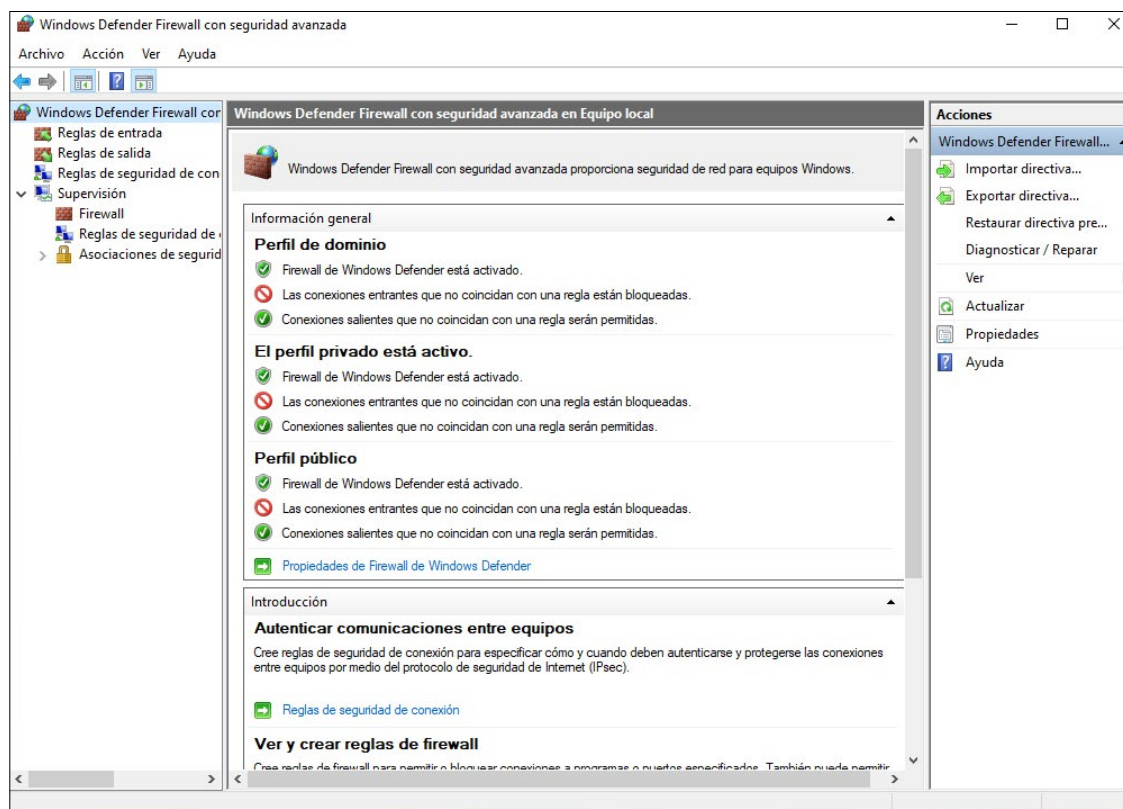
C. Utilización de cortafuegos en un sistema o servidor

Un firewall puede usarse localmente para proteger los accesos, no solo a una red, sino a un servidor individual. De hecho, la política de seguridad Zero Trust, que se está imponiendo en las configuraciones de red de ciberseguridad, implica que cada nodo (o servidor) tenga un control de acceso propio, por lo que el uso de un firewall en los servidores es habitual.

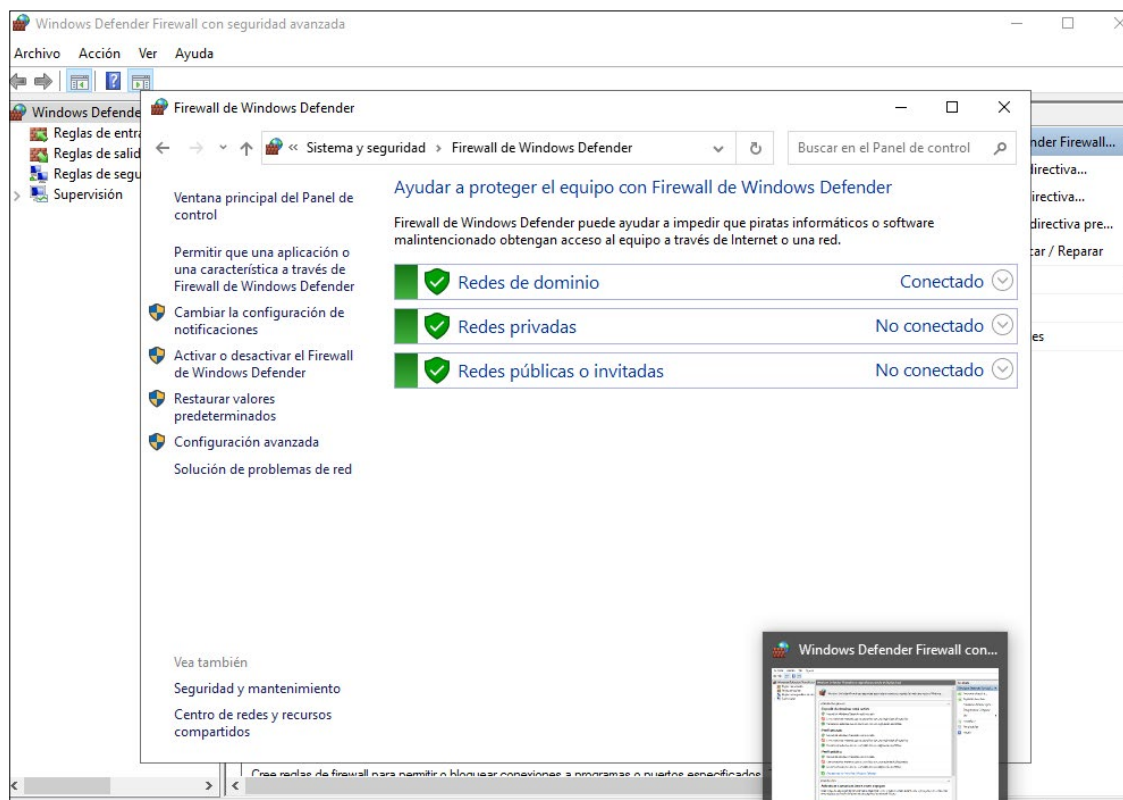
DEFINICIÓN

Zero Trust es la política de seguridad que parte de la base de que no se puede confiar en los dispositivos que acceden desde fuera de la red, pero tampoco en los que se conectan en la propia red local, ya que algunos son dispositivos que los trabajadores usan fuera de las instalaciones de la empresa (BYoD, Bring Your own Device).

Veamos cómo se puede configurar el firewall de Windows:



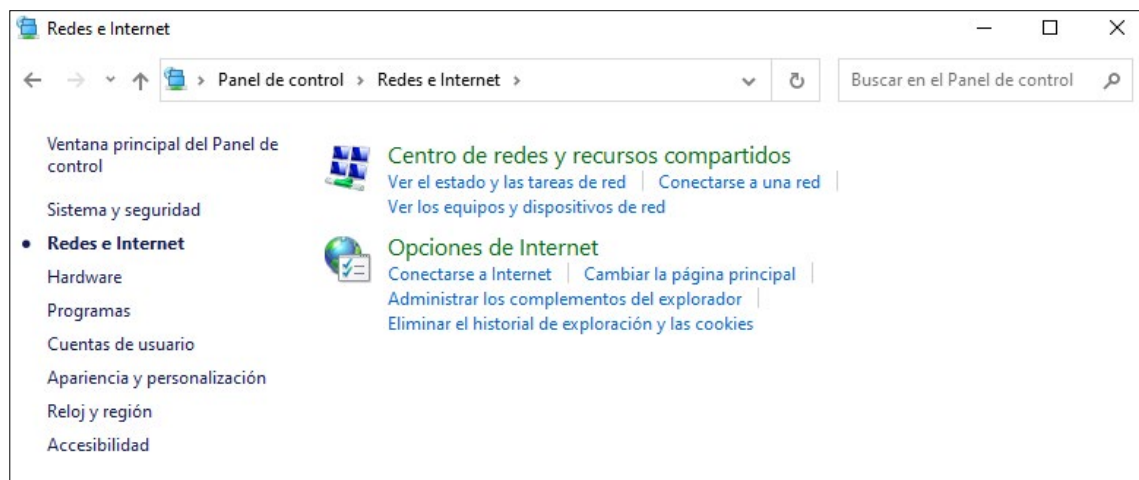
Como se ve en esta imagen, el firewall está activado y solo dejará acceder a través de una regla específica. En este caso hay tres perfiles:



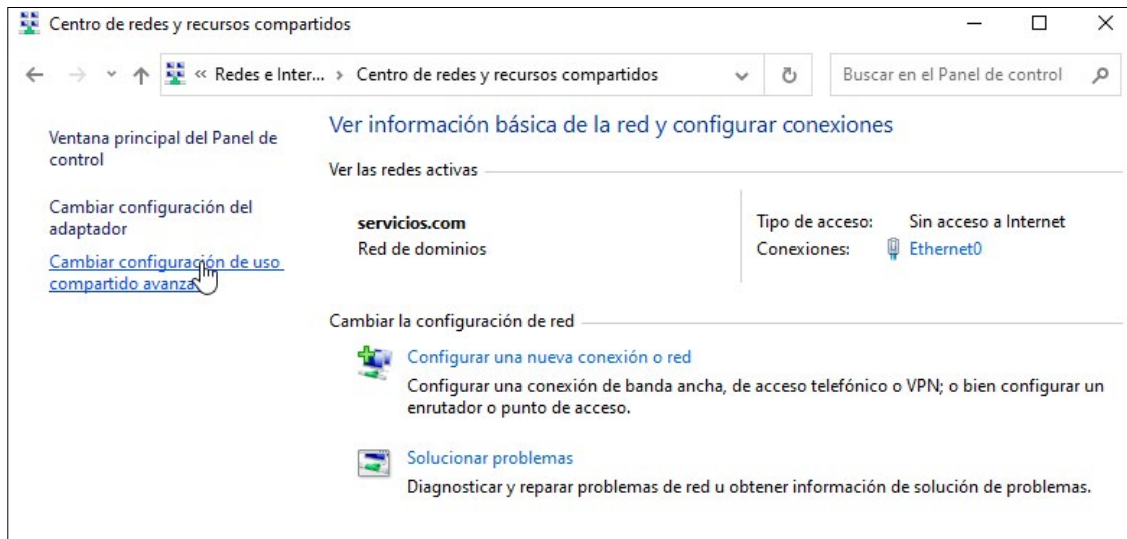
PERFIL	RESTRICCIONES	COMPARTICIÓN DE ARCHIVOS	DESCUBRIMIENTO DE RED	USO RECOMENDADO
Público	● Máxima seguridad (bloquea casi todo)	✗ No permitido	✗ No permitido	Redes desconocidas o Internet
Privado	● Moderado (menos restricciones)	✓ Permitido	✓ Permitido	LAN confiables sin AD
Dominio	● Personalizado (controlado por AD)	✓ Permitido	✓ Permitido	Redes corporativas con AD

Se puede cambiar entre estos perfiles de seguridad de la manera que se indica a continuación:

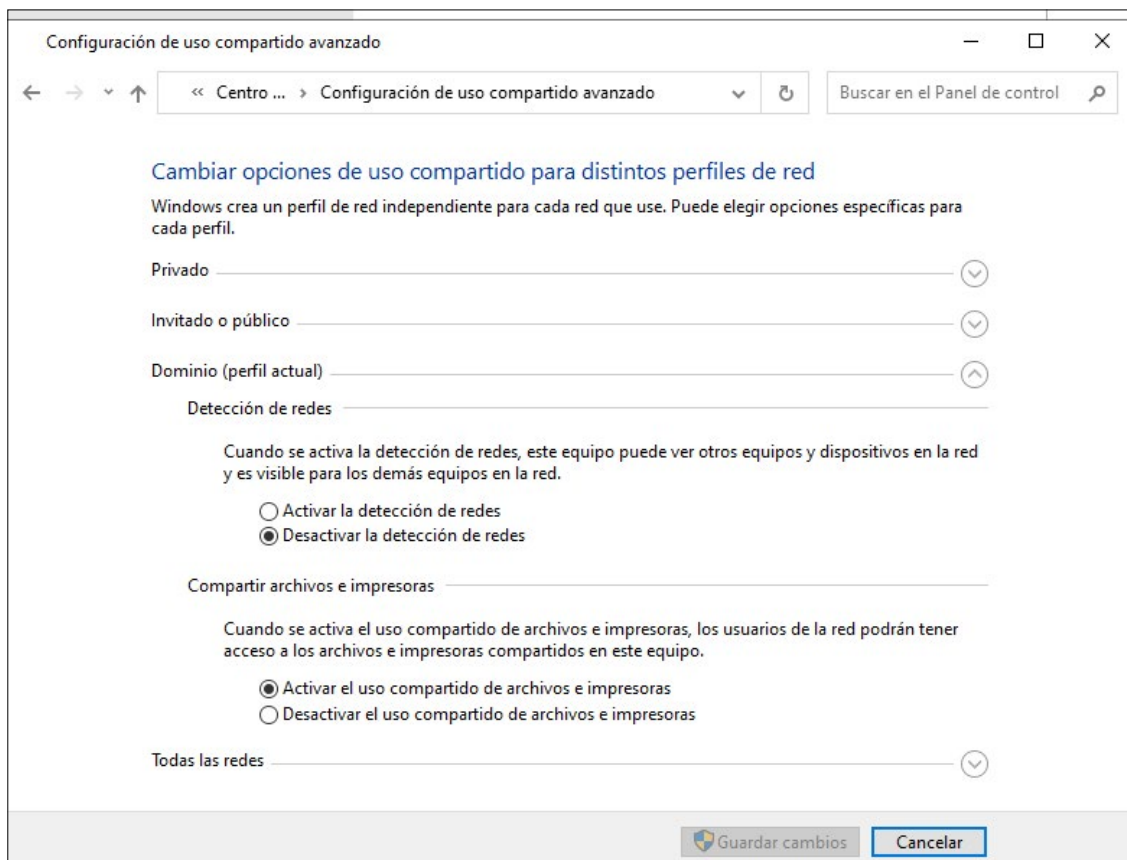
1. Entramos en *Centro de redes y recursos compartidos*.



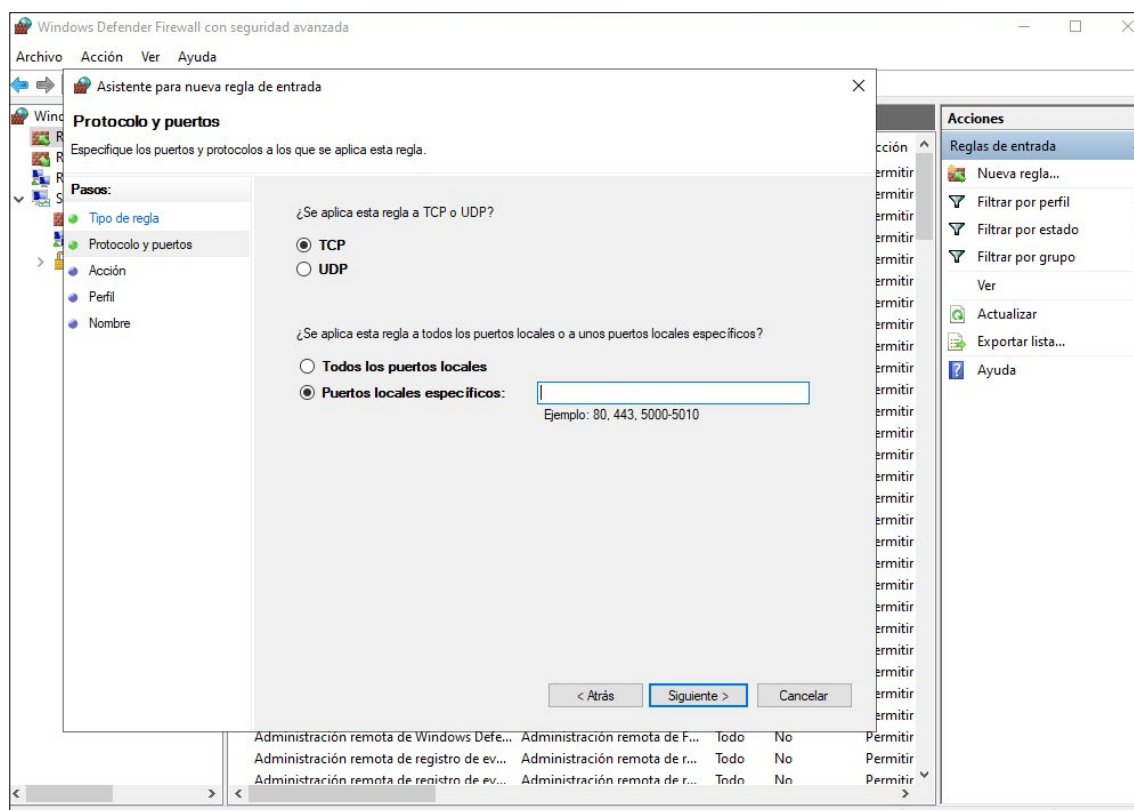
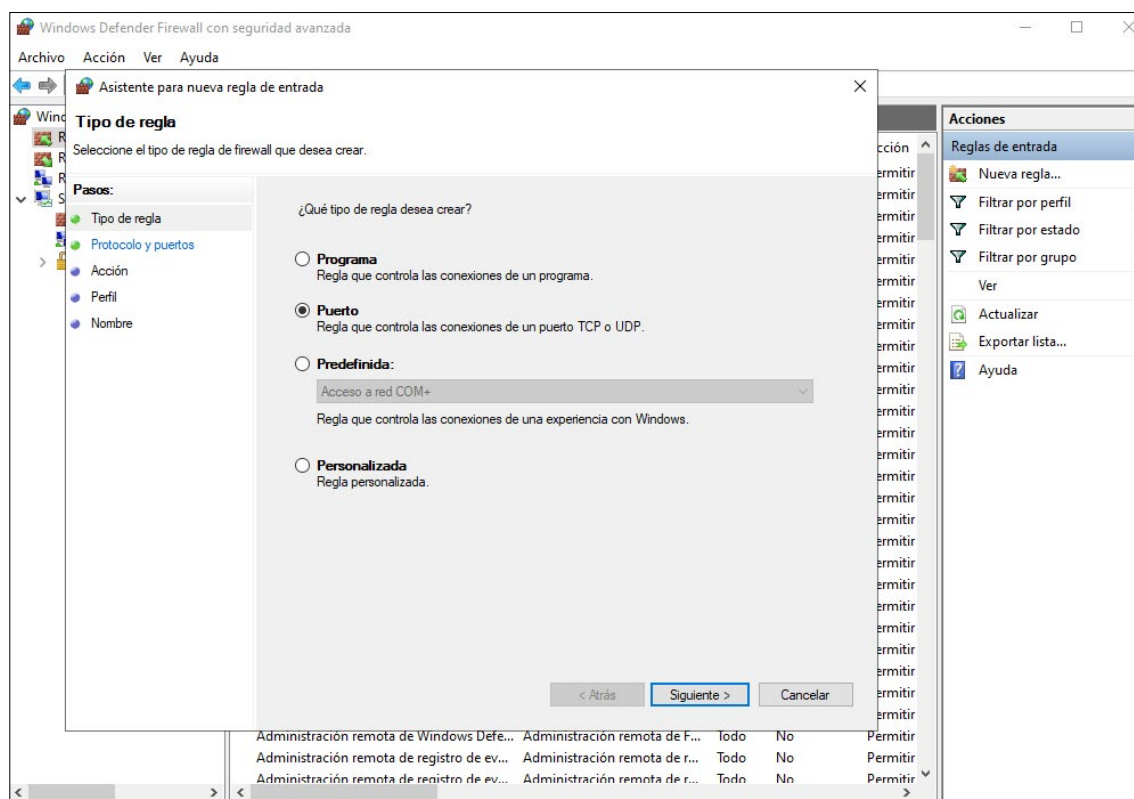
2. Seleccionamos *Cambiar configuración de uso compartido avanzado*:

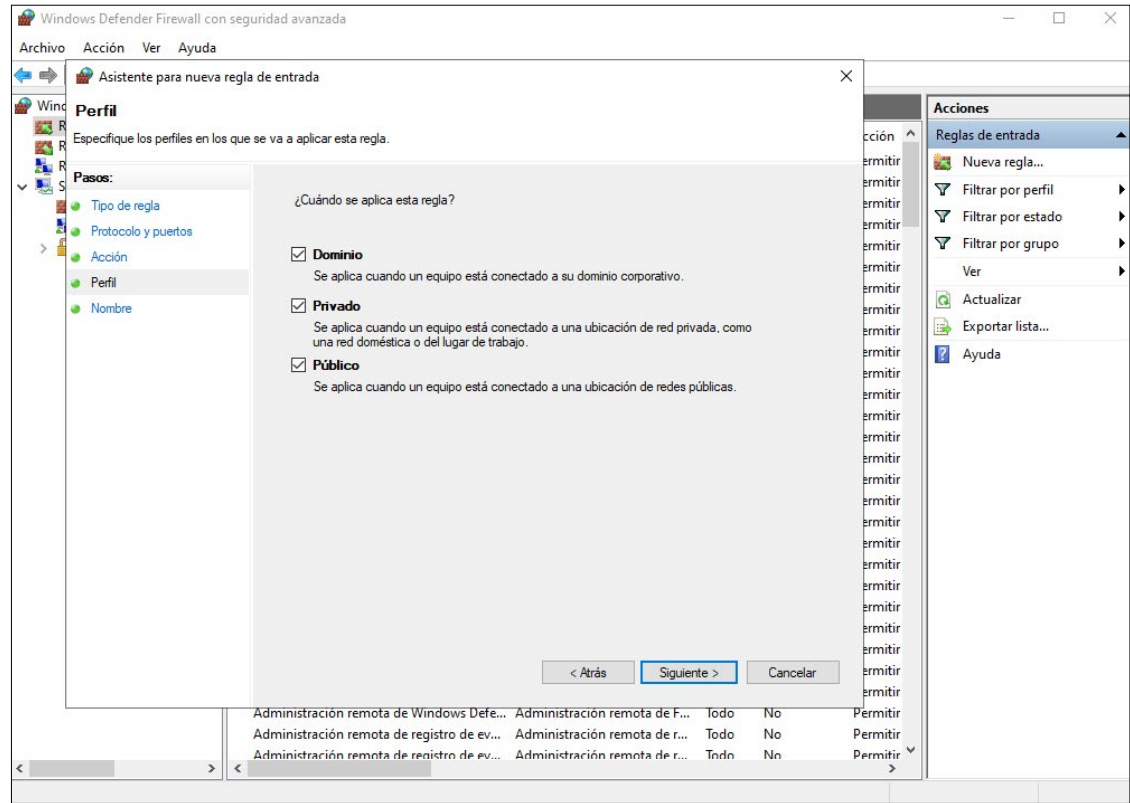
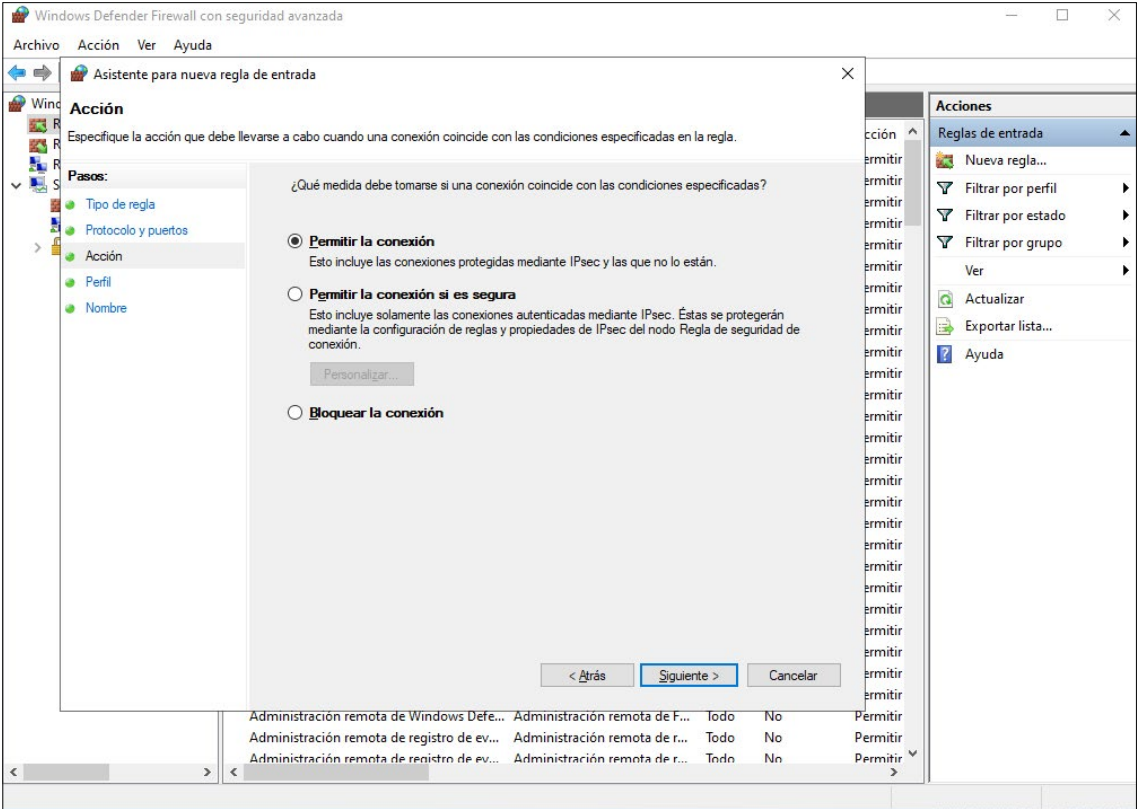


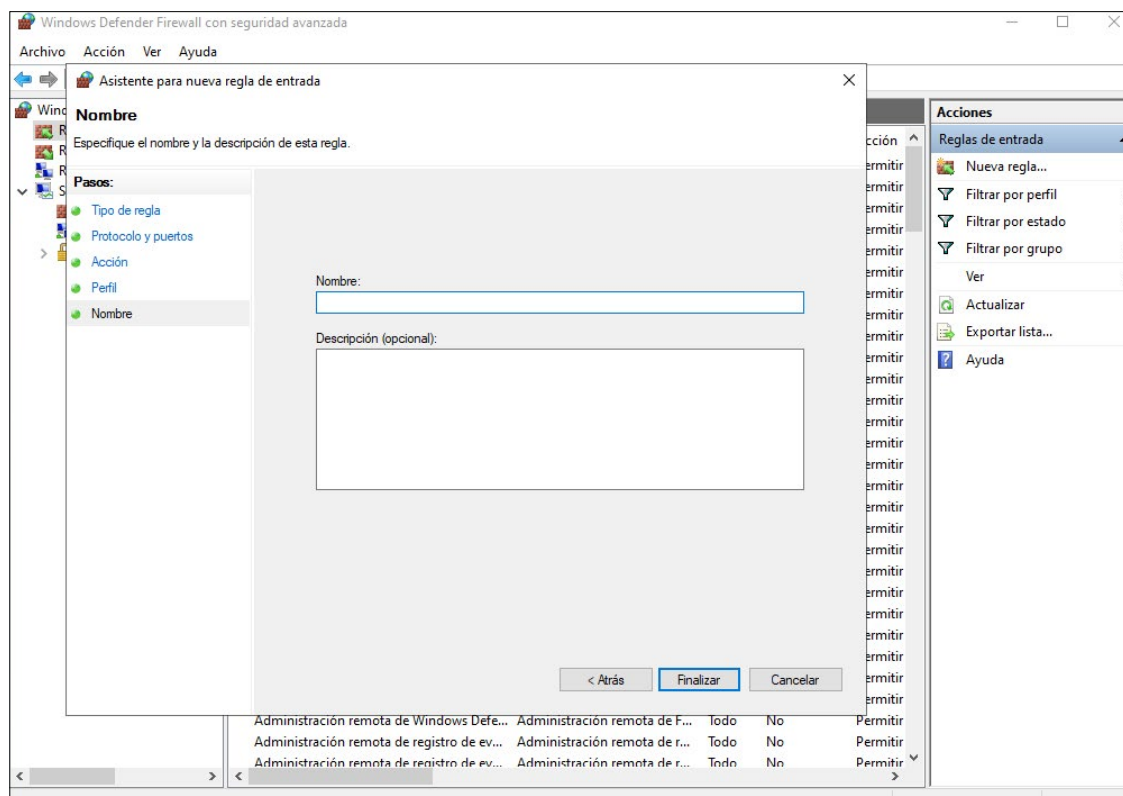
3. En esta pantalla, podemos activar o desactivar los perfiles que se van a aplicar:



- Dentro de cada uno de los perfiles, es posible indicar reglas de filtrado específicas para aceptar o denegar un determinado tipo de tráfico:



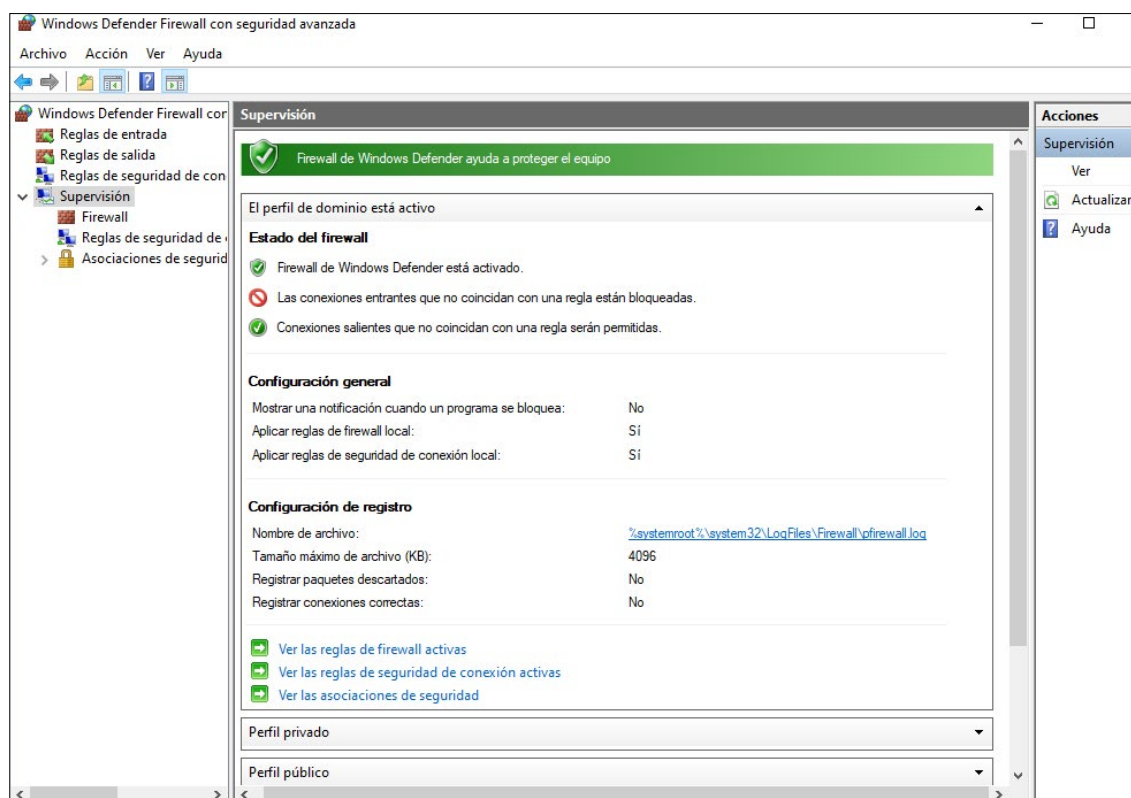




D. Logs y registros de actividad

Los firewalls generan logs de actividad que **registran todos los eventos que detectan** y permiten detectar intentos de ataque o accesos sospechosos.

Por ejemplo, en Windows podemos ver la configuración de logs en la siguiente imagen:



En Linux podemos ver en la siguiente imagen la configuración de logs:

```
stucom@stucom:/var/log$ ls ufw.log
ufw.log
stucom@stucom:/var/log$
```

Podemos ver parte del contenido en la siguiente imagen:

```
=TCP SPT=59783 DPT=8080 WINDOW=64240 RES=0x00 SYN URG=0
Feb 20 18:26:31 stucom kernel: [ 1022.224168] [UFW BLOCK] IN=enp0s3 OUT= MAC=08:00:27:08:f8:3b:00:45
:e2:09:9f:63:08:00 SRC=10.0.1.150 DST=10.0.1.111 LEN=52 TOS=0x00 PREC=0x00 TTL=128 ID=46693 DF PROTO
=TCP SPT=59813 DPT=8080 WINDOW=64240 RES=0x00 SYN URG=0
Feb 20 18:26:31 stucom kernel: [ 1022.224187] [UFW BLOCK] IN=enp0s3 OUT= MAC=08:00:27:08:f8:3b:00:45
:e2:09:9f:63:08:00 SRC=10.0.1.150 DST=10.0.1.111 LEN=52 TOS=0x00 PREC=0x00 TTL=128 ID=46694 DF PROTO
=TCP SPT=59814 DPT=8080 WINDOW=64240 RES=0x00 SYN URG=0
Feb 20 18:26:31 stucom kernel: [ 1022.475474] [UFW BLOCK] IN=enp0s3 OUT= MAC=08:00:27:08:f8:3b:00:45
:e2:09:9f:63:08:00 SRC=10.0.1.150 DST=10.0.1.111 LEN=52 TOS=0x00 PREC=0x00 TTL=128 ID=46696 DF PROTO
=TCP SPT=59816 DPT=8080 WINDOW=64240 RES=0x00 SYN URG=0
Feb 20 18:26:32 stucom kernel: [ 1023.224994] [UFW BLOCK] IN=enp0s3 OUT= MAC=08:00:27:08:f8:3b:00:45
:e2:09:9f:63:08:00 SRC=10.0.1.150 DST=10.0.1.111 LEN=52 TOS=0x00 PREC=0x00 TTL=128 ID=46697 DF PROTO
=TCP SPT=59814 DPT=8080 WINDOW=64240 RES=0x00 SYN URG=0
Feb 20 18:26:32 stucom kernel: [ 1023.225006] [UFW BLOCK] IN=enp0s3 OUT= MAC=08:00:27:08:f8:3b:00:45
:e2:09:9f:63:08:00 SRC=10.0.1.150 DST=10.0.1.111 LEN=52 TOS=0x00 PREC=0x00 TTL=128 ID=46698 DF PROTO
=TCP SPT=59813 DPT=8080 WINDOW=64240 RES=0x00 SYN URG=0
Feb 20 18:26:32 stucom kernel: [ 1023.476231] [UFW BLOCK] IN=enp0s3 OUT= MAC=08:00:27:08:f8:3b:00:45
:e2:09:9f:63:08:00 SRC=10.0.1.150 DST=10.0.1.111 LEN=52 TOS=0x00 PREC=0x00 TTL=128 ID=46699 DF PROTO
=TCP SPT=59816 DPT=8080 WINDOW=64240 RES=0x00 SYN URG=0
Feb 20 18:26:34 stucom kernel: [ 1025.224763] [UFW BLOCK] IN=enp0s3 OUT= MAC=08:00:27:08:f8:3b:00:45
:e2:09:9f:63:08:00 SRC=10.0.1.150 DST=10.0.1.111 LEN=52 TOS=0x00 PREC=0x00 TTL=128 ID=46700 DF PROTO
=TCP SPT=59814 DPT=8080 WINDOW=64240 RES=0x00 SYN URG=0
```



VIDEOLAB

Para consultar el siguiente vídeo sobre **Gestión de firewall en equipo Windows y Linux**, escanea el código QR o [pulsa aquí](#).

Partiendo de una máquina Windows, intentaremos hacer ping a otra Windows y a una Linux. Aprenderemos a configurar los firewalls de los dos entornos para que Windows admita ping (sin desactivar el firewall) y Linux lo limite.

2 CASO PRÁCTICO



PROBLEMAS DE SEGURIDAD Y FUNCIONES DEL FIREWALL

La empresa TecnoRed se dedica a la prestación de servicios en la nube para pequeñas y medianas empresas. Sus clientes confían en sus servidores para alojar bases de datos, correos electrónicos y aplicaciones web. Para garantizar la seguridad de su infraestructura, TecnoRed ha decidido mejorar su política de cortafuegos.

Actualmente, la red de la empresa está configurada de la siguiente manera:

- » Un firewall perimetral que filtra el tráfico externo y protege contra amenazas provenientes de Internet.
- » Un firewall interno que segmenta la red en distintas áreas, protegiendo los servidores más críticos.
- » Una DMZ donde se alojan el servidor web y el servidor de correo para ofrecer servicios accesibles desde el exterior sin comprometer la red interna.
- » Cortafuegos de host en cada servidor, configurados con reglas específicas para proteger cada sistema.

Recientemente, la empresa ha detectado los siguientes problemas de seguridad:

- » Ataques DDoS recurrentes sobre su servidor web, lo que ocasiona la caída del servicio.
- » Intentos de acceso sospechosos a su base de datos desde direcciones IP no autorizadas.
- » Conexiones SSH no registradas en los logs del firewall de uno de sus servidores internos.

- » Algunos clientes reportan ataques de inyección SQL en la aplicación web alojada en su servidor de la DMZ.
- » Un técnico de la empresa ha instalado sin permiso software de administración remota en un servidor crítico, lo que representa un riesgo para la seguridad.

Estas son las funciones del firewall:

- » Filtrado de tráfico en el firewall interno y segmentación de red.
- » Registro de actividad y firewall de host para restringir accesos.
- » Prevención de ataques mediante firewall perimetral y mitigación DDoS.
- » Políticas de seguridad Zero Trust y control en firewall de host.
- » Uso de un WAF (firewall de aplicación web) para filtrar tráfico malicioso.

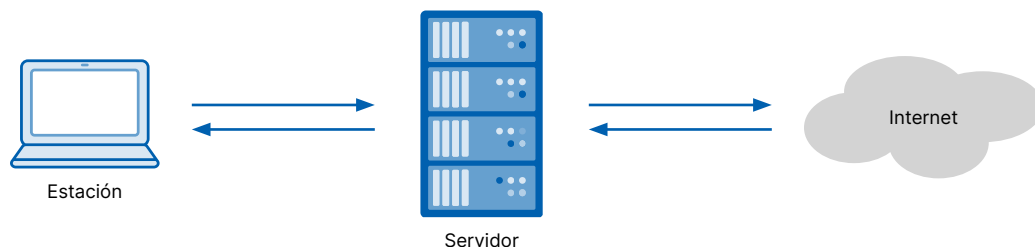
Relaciona las funciones con cada problema de seguridad detectado.

03 Proxy y seguridad en redes

El creciente volumen de tráfico en redes y la necesidad de garantizar la seguridad y el rendimiento en la comunicación han impulsado el uso de proxies. Estos dispositivos o servicios actúan como **intermediarios entre los clientes y los servidores**, permitiendo no solo mejorar el rendimiento mediante el almacenamiento en caché, sino también ofrecer mecanismos de filtrado, autenticación y control de acceso.

3.1. Conceptos básicos y funcionalidad del proxy

Un **proxy** es un servicio de red que actúa como intermediario en las comunicaciones entre un cliente y un servidor. Su funcionamiento se basa en recibir una petición del cliente (por ejemplo, una solicitud HTTP) y reenviarla al servidor de destino, de modo que el servidor no interactúa directamente con el cliente, sino con el proxy.



Esquema 3. Funcionamiento básico de un servidor proxy.

Al funcionar así, el proxy puede **analizar y filtrar el tráfico**, cortando la comunicación si se detectan condiciones no deseadas. Como tiene una memoria donde almacena las respuestas que ofrece, evita hacer solicitudes repetidas al servidor remoto, acelerando así la navegación, y además oculta la IP del cliente ante el servidor.

El filtrado de paquetes es la capacidad del proxy (y de los firewalls a nivel de red) para examinar y controlar el tráfico basándose en reglas definidas. Estas reglas pueden considerar:

- » Direcciones IP de origen o destino.
- » Puertos y protocolos.
- » Contenido de la URL o palabras clave.
- » Tipos de archivo o MIME types.

Esta funcionalidad permite bloquear accesos no autorizados o potencialmente peligrosos, incrementando la seguridad de la red.



WEB

¿Qué es un proxy y para qué sirve?:

<https://www.welivesecurity.com/la-es/2020/01/02/que-es-proxy-para-que-sirve/>

Ventajas

Control

El proxy puede limitar y restringir los derechos de los usuarios (permisos).

Velocidad

Si varios clientes van a pedir el mismo recurso, el proxy puede hacer de caché, es decir, guarda la respuesta de una petición para darla directamente cuando otro usuario la pida. Así no tiene que volver a contactar con el servidor destino y acaba más rápido.

Filtrado

Puede negarse a responder algunas peticiones si detecta que están prohibidas.

Anonimato

Si todos los usuarios se identifican como uno solo, es difícil que el recurso final al que han accedido pueda identificar cuál es el equipo origen de la petición.

Ahorro

Una máquina hace el trabajo de muchos usuarios.

Desventajas

Carga de trabajo

Un dispositivo tiene que hacer el trabajo de muchos usuarios.

Intromisión

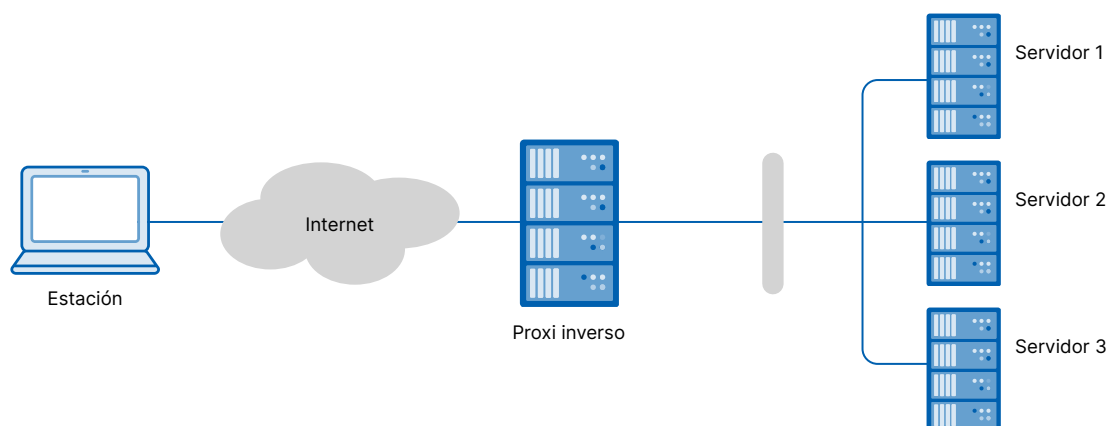
Al ser un equipo intermediario entre el origen y el destino de la información, toda la información que pasa por él queda registrada.

Incoherencia

Si el proxy hace caché, es posible que se equivoque y dé una respuesta antigua cuando hay una más reciente en el recurso destino. Este problema no existe con los servidores proxy actuales, ya que se conectan con el servidor remoto para comprobar que la versión que tienen en caché sigue siendo la misma que la existente en el servidor remoto.

3.2. Tipos de proxy

Proxy caché	Proxy transparente	Proxy inverso
Almacena temporalmente las respuestas de las peticiones realizadas a servidores remotos. Al hacerlo, cuando se repite una solicitud idéntica, el proxy puede devolver directamente la respuesta almacenada, reduciendo la latencia y el consumo de ancho de banda. Esta técnica mejora significativamente el rendimiento, especialmente en entornos con múltiples usuarios que acceden a los mismos recursos.	Actúa sin que el usuario tenga que configurarlo explícitamente en su dispositivo. En este caso, un router o dispositivo de red redirige automáticamente el tráfico destinado a determinados puertos (por ejemplo, el puerto 80 en HTTP) hacia el proxy. Esto facilita la supervisión del tráfico. Es decir, la puerta de enlace que recibirá el tráfico para Internet (con el puerto 80 de destino, por ejemplo) y el mismo dispositivo que hace de puerta de enlace enviará el tráfico al puerto de escucha del servidor proxy. De esta manera, el usuario no es consciente de que hay un proxy como intermediario en su conexión a Internet, debido a que no ha de configurar nada en su equipo cliente.	Como hemos visto, un servidor proxy recibe las peticiones de los clientes de la red y envía esas peticiones a Internet, siendo entonces el servidor proxy el que interactúa con los servidores exteriores. En el caso de que nosotros tengamos un servidor web en nuestra red, podemos colocar un servidor proxy inverso entre el servidor y el router, cuya función será la de recibir las peticiones desde el exterior y transferirlas al servidor web de nuestra red, de modo que puede prevenir ataques sobre el servidor; por ejemplo, un ataque DoS sería soportado por el servidor proxy y no por el servidor web.



Esquema 4. Funcionamiento de un proxy inverso.

3.3. Ejemplos de servidores proxy

A. Squid

Squid es

Estas son sus características:

- » Compatible con protocolos HTTP, HTTPS y FTP.
- » Soporte para caché web, mejorando tiempos de carga.
- » Control de acceso mediante listas ACL (Access Control Lists).
- » Compatible con autenticación (LDAP, Active Directory, etc.).
- » Permite la restricción de sitios web y el filtrado de contenido.



WEB

Página oficial de Squid: <http://www.squid-cache.org>.

B. CCProxy

CCProxy es un software comercial que permite configurar un servidor proxy en Windows, ofreciendo una interfaz sencilla y herramientas avanzadas para gestionar el tráfico de red.

Estas son sus características:

- » Compatible con HTTP, HTTPS, FTP, SOCKS, Telnet y otros protocolos.
- » Control de acceso basado en IP, usuario y contraseña.
- » Soporta ancho de banda limitado por usuario o grupo.
- » Integración con autenticación mediante Active Directory.
- » Incluye filtrado de contenido y bloqueo de sitios web.
- » Puede actuar como proxy web, correo y FTP.



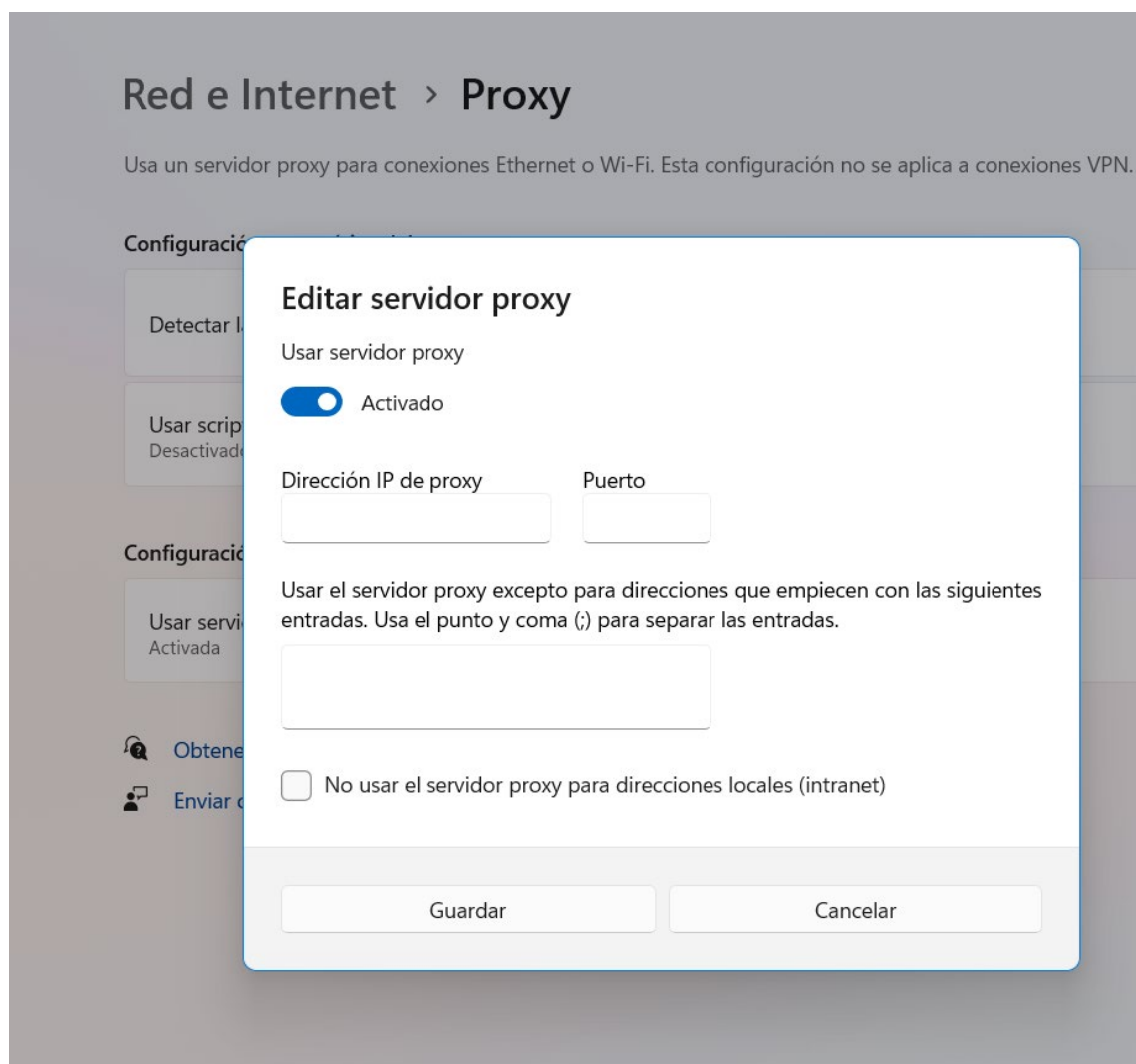
WEB

Página oficial de CCProxy: <https://www.youngzsoft.net/ccproxy/>.

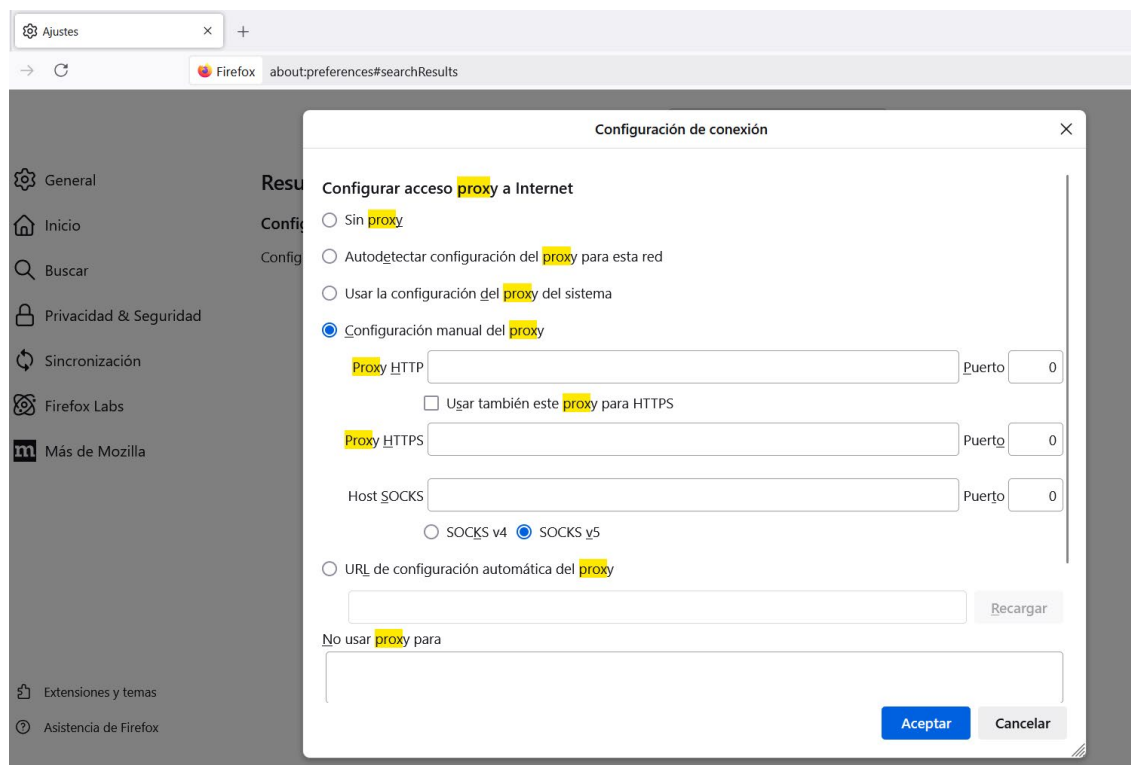
3.4. Configuración de clientes proxy

Para que un proxy funcione en un entorno de red, es necesario configurar los clientes (navegadores o aplicaciones) de modo que **envíen sus peticiones a través del servidor proxy**. Esta configuración puede realizarse de forma manual en cada aplicación o mediante políticas centralizadas en entornos corporativos (por ejemplo, utilizando scripts de configuración automática o GPO en Windows). En el caso del proxy explícito, el usuario debe introducir la dirección y el puerto del proxy en la configuración de red de su navegador.

El navegador Edge lo integra con Windows:



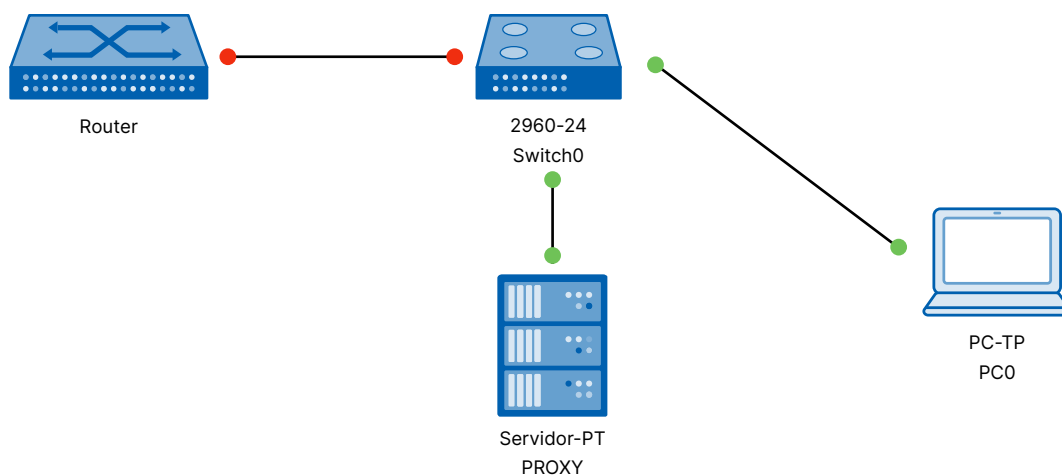
En navegadores independientes del sistema operativo, como Firefox, por ejemplo, el propio navegador tiene entre sus ajustes la configuración del proxy.



3.5. Instalación y configuración del proxy Squid

Squid es el **servidor proxy de código abierto más extendido** en entornos Linux y también dispone de versiones para Windows. A continuación, veremos la configuración de un servidor Linux en el que se instala Squid3 y se configura para que un cliente pueda salir a través de él.

En esta configuración las dos máquinas están en la misma red y el servidor solo tiene una tarjeta, por lo que la topología será como la siguiente:



Esquema 5. Ejemplo de configuración de un servidor Linux.

Primero instalamos el paquete en Linux:

```
root@debian-examen:~# apt-get install squid3
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias
Leyendo la información de estado... Hecho
Se instalarán los siguientes paquetes extras:
  libecap2 libltdl7 libnetfilter-conntrack3 squid-langpack squid3-common
Paquetes sugeridos:
  squidclient squid-cgi squid-purge resolvconf smbclient ufw winbindd
Se instalarán los siguientes paquetes NUEVOS:
  libecap2 libltdl7 libnetfilter-conntrack3 squid-langpack squid3 squid3-common
0 actualizados, 6 nuevos se instalarán, 0 para eliminar y 0 no actualizados.
Se necesita descargar 2.610 kB de archivos.
Se utilizarán 9.466 kB de espacio de disco adicional después de esta operación.
¿Desea continuar? [S/n] s
```

Una vez instalado el paquete, la configuración del sistema se hace en:

[/etc/squid3/squid.conf](#)

```
GNU nano 2.2.6 Fichero: squid.conf
# WELCOME TO SQUID 3.4.8
# -----
#
# This is the documentation for the Squid configuration file.
# This documentation can also be found online at:
#   http://www.squid-cache.org/Doc/config/
#
# You may wish to look at the Squid home page and wiki for the
# FAQ and other documentation:
#   http://www.squid-cache.org/
#   http://wiki.squid-cache.org/SquidFaq
#   http://wiki.squid-cache.org/ConfigExamples
#
# This documentation shows what the defaults for various directives
# happen to be. If you don't need to change the default, you should
# leave the line out of your squid.conf in most cases.
#
# In some cases "none" refers to no default setting at all,
# while in other cases it refers to the value of the option
# - the comments for that keyword indicate if this is the case.
#
# Configuration options can be included using the "include" directive.
# Include takes a list of files to include. Quoting and wildcards are
# supported.
#
# For example,
# include /path/to/included/file/squid.acl.config
#
# Includes can be nested up to a hard-coded depth of 16 levels.
# This arbitrary restriction is to prevent recursive include references
```

Una vez en el archivo de configuración, hemos de autorizar el acceso al proxy para las IP de la red local, para lo que activaremos una ACL (lista de control de acceso) que autorice esa red.

Miramos la dirección IP que tenemos en la parte LAN:

```
root@debian-examen:/etc/squid3# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:c9:8e:7e
          inet addr:192.168.23.137  Bcast:192.168.23.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fec9:8e7e/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:3023 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1819 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4147693 (3.9 MiB)  TX bytes:104316 (101.8 KiB)
          Interrupt:19 Base address:0x2000
```

Quitamos el # de la línea de la ACL que nos interesa activar:

```
#acl localnet src 10.0.0.0/8 # RFC1918 possible internal network
#acl localnet src 172.16.0.0/12 # RFC1918 possible internal network
acl localnet src 192.168.0.0/16 # RFC1918 possible internal network
#acl localnet src fc00::/7 # RFC 4193 local private network range
#acl localnet src fe80::/10 # RFC 4291 link-local (directly plugged)
```

Finalmente, hemos de activar la regla que deje pasar el tráfico controlado por la ACL que hemos creado, como puede verse en la siguiente imagen:

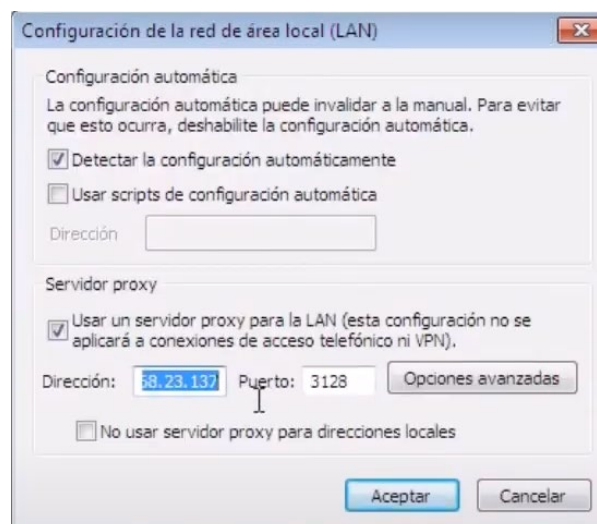
```
# Example rule allowing access from your local networks.
# Adapt localnet in the ACL section to list your (internal) IP networks
# from where browsing should be allowed
http_access allow localnet
http_access allow localhost
```

Una vez que tenemos esta mínima configuración, ya podemos usar nuestro servidor proxy desde un cliente, configurándolo como explicamos a continuación.

En el servidor tenemos la configuración por defecto sobre el puerto en que está escuchando:

```
# Squid normally listens to port 3128
http_port 3128
```

Así que en el cliente hemos de indicar la IP del servidor proxy y el puerto de escucha 3128:



Los logs del uso de Squid los podemos encontrar generalmente en:

`/var/log/squid/`

**WEB**

Configuración de proxy Squid con 2 tarjetas:

<https://alexcastel.wordpress.com/2017/04/18/proxy-squid-con-linux-configuracion-basica-con-proxy-con-dos-targetas/>

**WEB**

Información general sobre Squid:

<https://wiki.squid-cache.org/>

Además de la configuración básica que hemos visto, podemos establecer ACL para permitir o denegar el acceso según la IP, el dominio o la URL. Otra de las operaciones que Squid permite es restringir el uso del proxy solo a usuarios autorizados.

**WEB**

Squid con autenticación básica:

<https://alexcastel.wordpress.com/2020/04/29/squid-en-windows-autenticacion-basica/>

3 CASO PRÁCTICO



IMPLEMENTACIÓN DE PROXY EN LA EMPRESA NETSECURE

La empresa NetSecure se dedica a la consultoría en ciberseguridad y cuenta con una red interna de 100 empleados que acceden diariamente a Internet para investigar amenazas, consultar documentación y realizar pruebas de seguridad en entornos aislados. Debido al crecimiento de la empresa y la preocupación por la seguridad, han decidido implementar un servidor proxy para mejorar el control del acceso a la red, optimizar el ancho de banda y aumentar la privacidad de las conexiones.

La infraestructura de red de NetSecure cuenta con:

- » Un firewall perimetral que protege la red interna de accesos no autorizados.
- » Una conexión a Internet de alta velocidad, pero con límites en el ancho de banda.
- » Servidores internos y una DMZ con aplicaciones accesibles desde el exterior.
- » Estaciones de trabajo Windows y Linux utilizadas por los empleados.

Tras un análisis inicial, han identificado los siguientes problemas:

- » Consumo excesivo de ancho de banda debido a descargas innecesarias y uso inadecuado de Internet por parte de los empleados.

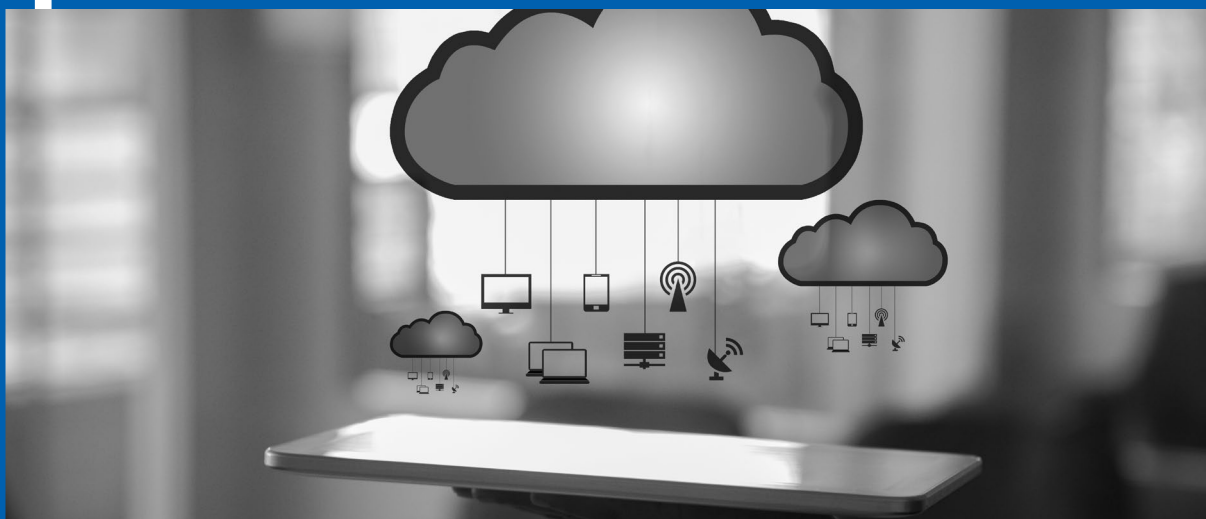
- » Falta de control sobre los sitios web visitados, lo que puede comprometer la seguridad de la empresa.
- » Fugas de información y riesgo de ataques, ya que los empleados acceden directamente a Internet sin medidas de anonimato.
- » Acceso público al servidor web corporativo, sin protección ante ataques de denegación de servicio (DoS).
- » Falta de registros de actividad, lo que impide identificar amenazas o realizar análisis forenses en caso de incidente.

¿Qué tipo de proxy recomendarías para cada uno de los problemas identificados? Explica tu elección.

Solucionario casos prácticos

1

SOLUCIÓN CASO PRÁCTICO



ANOMALÍAS EN RED Y POSIBLES ATAQUES

- » **Ransomware:** un usuario informa que sus archivos han sido cifrados y que en su pantalla aparece un mensaje exigiendo un pago en criptomonedas para recuperarlos.
- » **Cross-Site Scripting (XSS):** un usuario reporta que, al ingresar a la página web de la empresa, su navegador ejecuta automáticamente un código malicioso que lo redirige a otro sitio web sospechoso.
- » **Man-in-the-Middle (MitM):** se ha descubierto que un intruso ha estado interceptando las comunicaciones internas entre empleados y modificando mensajes antes de que lleguen a su destinatario original.
- » **Inyección SQL:** un administrador de bases de datos observa que un atacante ha logrado ejecutar comandos en la base de datos introduciendo código malicioso en un formulario de inicio de sesión.
- » **Phishing:** varios empleados recibieron un correo electrónico que parecía provenir del Departamento de Recursos Humanos, solicitándoles que actualizaran sus credenciales en un enlace externo. Posteriormente, se detectaron accesos no autorizados a sus cuentas.

- » **Sniffing:** en la red de la empresa, se han encontrado dispositivos sospechosos que están capturando paquetes para obtener información confidencial.
- » **Denegación de servicio distribuida (DDoS):** el servidor de la empresa ha recibido una gran cantidad de tráfico desde múltiples direcciones IP, lo que ha provocado la caída del sitio web.

2 SOLUCIÓN CASO PRÁCTICO



PROBLEMAS DE SEGURIDAD Y FUNCIONES DEL FIREWALL

PROBLEMA DETECTADO

FUNCIÓN DEL FIREWALL

Ataques DDoS sobre el servidor web

Prevención de ataques mediante firewall perimetral y mitigación DDoS

Intentos de acceso a la base de datos desde IP no autorizadas

Filtrado de tráfico en el firewall interno y segmentación de red

Conexiones SSH no registradas

Registro de actividad y firewall de host para restringir accesos

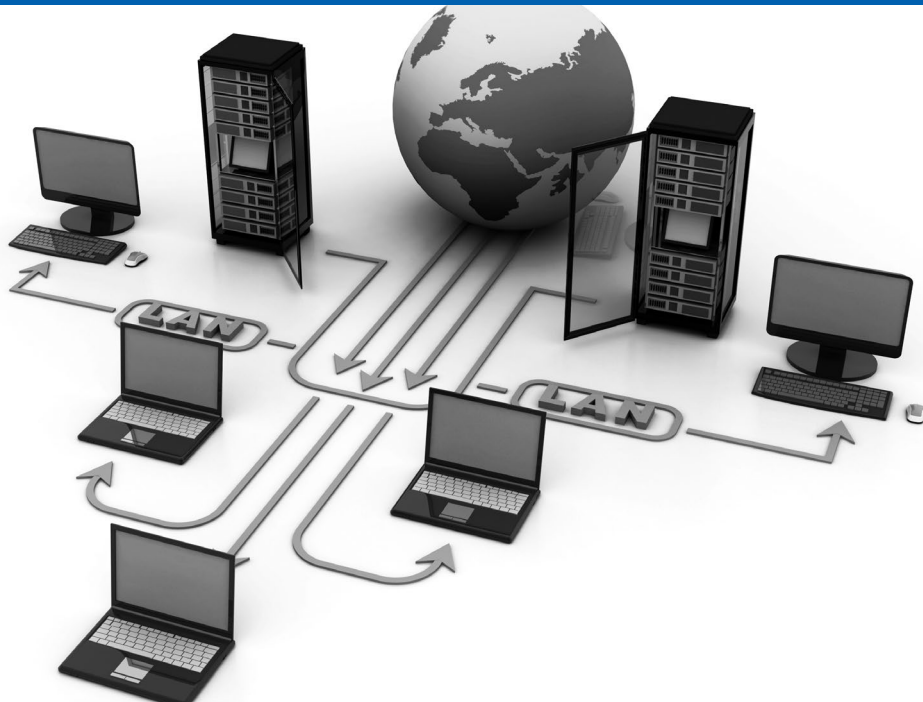
Inyección SQL en la aplicación web

Uso de un WAF (firewall de aplicación web) para filtrar tráfico malicioso

Instalación de software no autorizado en servidor crítico

Políticas de seguridad Zero Trust y control en firewall de host

3 SOLUCIÓN CASO PRÁCTICO



IMPLEMENTACIÓN DE PROXY EN LA EMPRESA NETSECURE

PROBLEMA	TIPO DE PROXY	JUSTIFICACIÓN
Consumo excesivo de ancho de banda	Proxy caché	Reduce la carga al almacenar respuestas repetidas
Falta de control sobre sitios web	Proxy transparente	Permite filtrar tráfico sin configuración en clientes
Fugas de información y anonimato	Proxy anónimo	Oculto la IP de los empleados en conexiones externas
Protección del servidor web	Proxy inverso	Bloquea tráfico malicioso antes de llegar al servidor
Falta de registros de actividad	Proxy con logging	Proporciona auditoría y registro de accesos

Enlaces de interés

Página para la lucha contra el ransomware:

<https://www.nomoreransom.org/>

Cómo prevenir ataques DoS y DDoS:

<https://www.cloudflare.com/es-es/learning/ddos/what-is-a-ddos-attack/>

Documentación oficial de pfSense:

<https://docs.netgate.com/pfsense/en/latest/firewall/index.html>

¿Qué es una DMZ?

<https://www.incibe.es/empresas/blog/dmz-y-te-puede-ayudar-proteger-tu-empresa>

Información sobre instalación de pfSense:

<https://docs.netgate.com/pfsense/en/latest/firewall/index.html>

¿Qué es un proxy y para qué sirve?:

<https://www.welivesecurity.com/la-es/2020/01/02/que-es-proxy-para-que-sirve/>

Página oficial de Squid:

<http://www.squid-cache.org>

Página oficial de CCProxy:

<https://www.youngzsoft.net/ccproxy/>

Configuración de proxy Squid con 2 tarjetas:

<https://alexcastel.wordpress.com/2017/04/18/proxy-squid-con-linux-configuracion-basica-con-proxy-con-dos-targetas/>

Información general sobre Squid:

<https://wiki.squid-cache.org/>

Squid con autenticación básica:

<https://alexcastel.wordpress.com/2020/04/29/squid-en-windows-autenticacion-basica/>

Glosario

- » **ACL (Access Control List):** Lista de control de acceso que define qué tráfico de red está permitido o bloqueado en un firewall o dispositivo de seguridad.
- » **Ataque activo:** Tipo de ataque en el que el atacante modifica o interfiere con los sistemas o la información, como la inyección SQL o el ransomware.
- » **Ataque pasivo:** Tipo de ataque en el que se intercepta la información sin modificarla, como el sniffing.
- » **Autenticación multifactor (MFA):** Método de seguridad que requiere más de un factor para verificar la identidad de un usuario.
- » **Botnet:** Red de dispositivos comprometidos controlados de forma remota por un atacante para realizar ataques como DDoS.
- » **BYoD (Bring Your own Device):** Política que permite a los empleados usar sus propios dispositivos personales en la red de la empresa, aumentando los riesgos de seguridad.
- » **Cifrado:** Técnica de protección de datos que transforma la información en un formato ilegible sin una clave de descifrado.
- » **Cortafuegos (firewall):** Dispositivo o software que filtra y controla el tráfico de red según reglas de seguridad predefinidas.
- » **Cross-Site Scripting (XSS):** Ataque en el que un atacante inyecta scripts maliciosos en una página web para ejecutar código en el navegador del usuario.
- » **Denegación de servicio (DoS):** Ataque que inunda un servidor o red con tráfico excesivo para colapsarlo.
- » **Denegación de servicio distribuida (DDoS):** Versión avanzada de DoS en la que múltiples dispositivos atacan simultáneamente un sistema.
- » **DMZ (zona desmilitarizada):** Segmento de red que aísla servidores accesibles desde el exterior para proteger la red interna.
- » **Escaneo de puertos:** Técnica utilizada para identificar puertos abiertos en un sistema y detectar posibles vulnerabilidades.

- » **Exploit:** Código o técnica utilizada para aprovechar vulnerabilidades en un sistema y obtener acceso no autorizado.
- » **Filtrado de paquetes:** Técnica utilizada por los cortafuegos para analizar y decidir si un paquete de datos debe ser permitido o bloqueado.
- » **IDS (Intrusion Detection System):** Sistema que monitorea el tráfico de red en busca de actividades sospechosas o maliciosas.
- » **Inyección SQL:** Tipo de ataque en el que se manipulan consultas SQL para acceder o modificar bases de datos de manera ilícita.
- » **IPS (Intrusion Prevention System):** Sistema que, además de detectar intrusiones como un IDS, bloquea automáticamente actividades sospechosas.
- » **Man-in-the-Middle (MitM):** Ataque en el que un atacante intercepta y manipula la comunicación entre dos partes sin que estas lo noten.
- » **Malware:** Software malicioso diseñado para dañar, espiar o tomar el control de un sistema sin el consentimiento del usuario.
- » **Nmap:** Herramienta utilizada para escanear redes y descubrir hosts, puertos abiertos y vulnerabilidades.
- » **Phishing:** Técnica de ingeniería social que engaña a los usuarios para que revelen información confidencial a través de correos o sitios web falsos.
- » **Proxy:** Servidor intermediario que gestiona y filtra el tráfico de red para mejorar la seguridad, la privacidad y el rendimiento.
- » **Ransomware:** Tipo de malware que cifra archivos de la víctima y exige un rescate para desbloquearlos.
- » **Registro de actividad (logging):** Proceso de recopilación de eventos en un sistema para el monitoreo y la auditoría de seguridad.
- » **Segmentación de red:** Técnica que divide una red en segmentos más pequeños para mejorar la seguridad y minimizar el riesgo de propagación de amenazas.
- » **Sniffing:** Técnica de interceptación de tráfico de red para capturar información sin ser detectado.

- » **Spoofing:** Técnica de suplantación de identidad en la que un atacante falsifica direcciones IP, correos electrónicos u otros datos.
- » **Squid:** Servidor proxy de código abierto utilizado para caché web y filtrado de contenido en redes empresariales.
- » **Telnet:** Protocolo de acceso remoto no seguro, reemplazado por SSH debido a su falta de cifrado.
- » **UFW (Uncomplicated Firewall):** Herramienta de firewall en Linux utilizada para administrar reglas de filtrado de tráfico de forma sencilla.
- » **VPN (Virtual Private Network):** Red privada virtual que cifra la conexión a Internet para garantizar la seguridad y la privacidad en la comunicación.
- » **WAF (Web Application Firewall):** Cortafuegos que protege aplicaciones web filtrando el tráfico malicioso y bloqueando ataques como la inyección SQL y el XSS.
- » **Wireshark:** Herramienta de análisis de tráfico de red utilizada para monitorear y diagnosticar problemas de seguridad.

Bibliografía

Sallis, E., Caracciolo, C. y Rodríguez M. (2010). *Ethical Hacking: un enfoque metodológico para profesionales*. Alfaomega.

García Rambla, J. L. (2012). *Ataques en redes de datos IPv4 e IPv6*. 4.^a edición.

Cloudflare (s. f.). «¿Qué es un ataque DDoS?». Disponible en: <https://www.cloudflare.com/es-es/learning/ddos/what-is-a-ddos-attack/>

UAX FP